HELIOS

Managed detection and response, with AI first response on every alert

What we built and how we built it: the platform, its modules, the attack-surface model, Build & Price, the public website and estimator, and the principles behind every decision.

Technical and product overview · 25 October 2026
Repository: dharani2d/helios · branch claude/codebase-status-review-btjw26

Contents

1. Executive summary **4**

What it does, in one page . . . 4

2. Our approach **5**

2.1 Real data only . . . 5

2.2 Honest automation . . . 5

2.3 Human in the loop . . . 5

2.4 Traceable AI . . . 5

2.5 Secure by default . . . 5

2.6 One platform, one write path . . . 6

2.7 Verify before shipping . . . 6

3. Where HELIOS came from **7**

3.1 Timeline . . . 7

4. Architecture **8**

4.1 Technology stack . . . 8

4.2 Tenancy, roles and scope . . . 8

4.3 One write path . . . 9

4.4 Data model . . . 9

4.5 Reference data in the database . . . 9

5. Security operations modules **10**

5.1 Overview . . . 10

5.2 Cases & Alerts . . . 10

5.3 AI first responder and response actions . . . 12

5.4 Investigations . . . 12

5.5 Email & file forensics . . . 13

5.6 Agent governance . . . 14

5.7 Threat intelligence . . . 15

5.8 Response playbooks . . . 16

5.9 ATT&CK; coverage and the attack graph . . . 17

5.10 Audit log . . . 18

5.11 Reports and PDFs . . . 19

5.12 Clients, team, tools and endpoints . . . 20

5.13 Settings, REST API and the installable app . . . 21

6. The whole attack surface **23**

6.1 Priorities that move with the organisation . . . 23

6.2 28 capabilities . . . 24

6.3 The inventory by asset group . . . 24

7. Build & Price **26**

7.1 The calculator . . . 26

7.2 Platform fit . . . 26

7.3 Upgrade review . . . 26

7.4 Stack advisor: rules first, AI on top . . . 27

7.5 Solution designer . . . 28

7.6 Tool catalog . . . 29

8. Public website and estimator **30**

8.1 The estimator . . . 31

8.2 Safety of a public price tool . . . 33

9. Security and trust **35**

10. Test environment and test data **35**

11. Quality and verification **35**

12. Limits and next steps **37**

12.1 Known limits . . . 37

12.2 Suggested next steps . . . 37

Appendix A. Routes **38**

Appendix B. Source layout **38**

Appendix C. More screens **38**

1. Executive summary

HELIOS is a managed detection and response (MDR) platform for a small security company. One console runs the security operations centre (SOC) for many client organisations at once. Client tools stream alerts into a single case queue; AI agents do the first containment and initial analysis; analysts do the primary analysis and approve anything risky; and a Build & Price configurator designs and quotes the service. A public website explains the service and lets prospects estimate their price and request a formal quote.

It was built by merging four earlier projects, each a separate prototype in Python or JavaScript, into one TypeScript application on a single data model. That is: SignalFusionCore (SIEM detection), ASIP (autonomous investigations), DESAS (email and file forensics) and AEGIS (AI-agent governance). Every module was ported, the bugs found on the way were fixed and written down, and the product was then extended into a multi-client MDR service with pricing, an attack-surface model and a website.

19 modules in one console	**11** roles with their own navigation and permissions	**39** database tables, 11 migrations	**74** security tools in the catalog
9 asset groups across the attack surface	**28** protection capabilities	**133** MITRE ATT&CK techniques; 65 detectable	**211** automated tests (193 unit + 18 DB)

What it does, in one page

Area	What it does
Security operations	One case queue for SIEM alerts, vendor alerts, log investigations, email forensics and AI-agent governance, with tiered escalation, SLAs from each client's plan, comments, watchers and notifications.
AI first response	On every new case an AI agent triages, explains its verdict with cited evidence and proposes containment. A deterministic policy decides what runs, what waits for approval and what is only suggested.
Response	Containment goes through each client's response connector (a signed webhook). Without one, the action is left to do by hand and only counts once an analyst confirms it. Every action is audited and can be rolled back.
Analysis	Log investigations (.evtx, Sysmon, EDR and SIEM exports, Excel, password-protected ZIPs) and email and file forensics (.eml/.msg, macros, QR codes, OCR, link detonation).
Intelligence and assurance	Threat-intel store with public feeds, approval-gated playbooks, ATT&CK coverage, an attack graph across cases, a hash-chained audit log, reports and PDFs.
Commercial	Build & Price across 9 asset groups and 28 capabilities, upgrade review, a rules-plus-AI stack advisor, a solution designer, versioned quotes and a public estimator that turns visitors into quote requests.

2. Our approach

A handful of principles were set early and applied to every module. They explain most of the design decisions in the rest of this document.

2.1 Real data only

HELIOS ships no sample clients, invented prices or fake intelligence. The legacy projects had all three: hardcoded "known bad" IP lists, in-app attack simulators that filled dashboards, and placeholder prices. All of that was removed.

- **Seeded:** only facts. That covers vendors' published list prices (each with its source URL, or "by quote" where the vendor doesn't publish one), Anthropic's published model prices, the MITRE ATT&CK reference set, the public threat-feed addresses (disabled until enabled), starter playbooks and agent profiles.
- **Entered by the company:** its plans, rates, SLAs and exchange rates. A first-run checklist guides the admin, and a quote that needs a price nobody has set says so and can't be saved.
- **Test data** lives in a separate, clearly labelled seed, and a database can be marked as a test environment, with a banner on every page.

2.2 Honest automation

The platform never claims something happened that didn't. A response action with no connector to carry it out ends up "to do by hand"; it invents no ticket IDs and doesn't mark the endpoint isolated. A case only counts as contained when containment has actually executed. Prices are always computed by the calculator, never written by an AI.

2.3 Human in the loop

AI agents do the first, fast work; humans decide. Each client's plan sets the most autonomy its agents may take, and each client gives or withholds consent. A deterministic policy covers the global kill switch, per-agent autonomy, allowed actions, confidence bar, critical-endpoint guard and rate limit. It decides whether an action is suggested, queued for approval, executed or blocked. That function is pure and unit-tested.

2.4 Traceable AI

- Agents must cite numbered evidence (D1, E3, I2…). A grounding check rejects claims and targets the evidence doesn't contain.
- The stack advisor's AI may only choose among candidates the rules have already priced. Picks outside that list are discarded, and every pick carries plain-language reasons.
- Every AI run is logged with its provider, model, tokens and cost; analysts can agree or disagree with each one.
- With no model configured, a built-in deterministic engine answers instead, so the product works offline.

2.5 Secure by default

- Every page and server action re-checks the session, the role's permissions and the client scope. An out-of-scope case looks like a missing one.

- Tokens (ingest, agent, API) are shown once and stored only as hashes. Provider keys are sealed with AES-256-GCM.
- The audit log is hash-chained under an advisory lock, so it can't fork, and it is verifiable at any time.
- Public website submissions are sanitised server-side: commercial terms are reset, and costs and margins never leave the console.

2.6 One platform, one write path

Every source files its findings through the same case writer, so the case list, case view, ATT&CK matrix, indicator store and playbook triggers behave identically for SIEM alerts, investigations, forensics and agent governance.

2.7 Verify before shipping

Each change was type-checked, linted and covered by unit and database integration tests, then driven in a real browser. Bugs found in the legacy code were fixed and recorded in docs/porting-notes.md, rather than carried over silently.

3. Where HELIOS came from

Before HELIOS there were four separate projects, built between January and July 2026. They live on, untouched, under legacy/ for reference.

Project	What it was	Became in HELIOS
SignalFusionCore	A JavaScript SIEM: 4 log adapters, 11 detectors, a risk model, 48 attack scenarios, an Express API with no authentication and an in-app attack simulator.	Cases & Alerts, the risk model, the attack graph, Reports and REST API v1. The 48 scenarios became test fixtures.
ASIP	Autonomous Security Investigation Platform (Python): a multi-agent swarm for triage, root cause and QA over uploaded logs, with a playbook RAG.	Investigations, with a grounded Claude agent pipeline and a deterministic fallback. Playbook recommendations with reasons replace the RAG.
DESAS	A desktop email and file forensics app (Python + Eel, Windows .exe builds via CI) with sandbox screenshots and a point-based verdict model.	Email & File Forensics in TypeScript; the installable web app replaces the desktop shell.
AEGIS	AI-agent governance: constitution, reasoning-drift, DLP / prompt-injection firewall and intent policy checks.	Agent Governance with a live runtime API, adaptive trust and automatic revocation.

3.1 Timeline

When	Milestone
Jan – Mar 2026	DESAS forensics app: AbuseIPDB, HTML forensics, verdict explanations, Windows builds and CI.
Jun 2026	ASIP: multi-agent investigation portal, MITRE timeline, settings and model routing.
Jul 2026	DESAS hardening: secrets removed from source, broken tests fixed, frozen-exe packaging bugs fixed.
21 Sep 2026	HELIOS initialised. The four projects were imported and moved under legacy/; the Next.js 16 foundation, auth and data model were scaffolded; Agent Governance was the first module ported.
23 Oct 2026	The shared case writer, audit chain and threat-intel and playbook engines. Cases & Alerts, Threat Intelligence, Playbooks, ATT&CK coverage, the Audit Log, Investigations (Claude swarm) and Forensics. Tests, CI and docs.
24 Oct 2026	Outlook .msg, related-case memory, MxToolbox. The multi-client MDR platform: tenants, roles, AI first response, tools and integrations, Build & Price. Then real data only, .evtx/.xlsx intake, the test environment and Settings, Reports and PDFs, the attack graph, password-protected archives and playbook recommendations.
25 Oct 2026	OCR and QR decoding, VBA macro recovery, link detonation through an egress proxy, REST API v1, the installable app. Then the public website and estimator, upgrade review and stack advisor, and the whole-attack-surface model with the solution designer.

The repository holds 100 commits; 37 of them are HELIOS itself (September–October 2026). The application is about 36,900 lines of TypeScript, not counting tests, with 21 test files.

4. Architecture

4.1 Technology stack

Layer	Choice	Why
Framework	Next.js 16 (App Router, Server Actions, proxy.ts, after()), React 19, TypeScript	One codebase for the console, the API and the website. Server Actions keep writes on the server, and after() runs background work such as AI and investigations.
UI	Tailwind CSS 4, shadcn/ui, ECharts, Cytoscape	Light and dark themes, charts, and process and attack graphs.
Data	PostgreSQL 16 with Prisma 6	Relational integrity for tenants, cases and audit; advisory locks for the audit chain.
Auth	Auth.js v5 credentials, lockout after repeated failures	Self-hosted, with no third-party identity dependency.
AI	Anthropic SDK (structured outputs) and any OpenAI-compatible local server (Ollama, LM Studio, vLLM)	Cloud AI today, local or offline models when a client needs data residency.
Validation	Zod 4 schemas at every boundary	Quote configs, settings, triggers and AI outputs are all validated.
Documents	@react-pdf/renderer	Service reports, incident reports and quotes as PDFs.
Tests	Vitest unit tests and a Postgres integration suite; Playwright for browser checks	Fast pure tests plus real-database coverage.

4.2 Tenancy, roles and scope

Each client is a tenant with a service plan. The plan sets its SLA targets, the most autonomy its AI agents may take, and what it pays. There are 11 roles: platform admin, SOC manager, tier-1/2/3 analysts, threat hunter, detection engineer, auditor, account manager, client admin and client stakeholder. A single client-safe can() drives both the navigation and the server checks. Every query is scoped:

- client users see only their own tenant;
- analysts can be limited to security domains (endpoint, identity, email, network, cloud, AI agents), so they see only those queues;
- staff can focus on one client through the tenant switcher.
- The user is re-read from the database on every request, so a deactivation or role change applies immediately.

4.3 One write path

Every module files findings through src/lib/cases/writer.ts. That one path gives every source the same de-duplication, ATT&CK mapping, indicator scoring, audit entry and playbook evaluation.

```
module pipeline --> createCase / appendToCase
                    |- Case row (SIEM_ALERT | SOC_INVESTIGATION | EMAIL_ANALYSIS | AGENT_GOVERNANCE)
                    |- Detection rows          (deduplicated by fingerprint)
                    |- TimelineEntry rows
                    |- CaseMitreTechnique      (resolved against the shared ATT&CK catalog)
                    |- ThreatIndicator + CaseIndicator   (built-in intel scored inline)
                    |- SecurityEvent links     (telemetry that backs the case)
                    |- AuditLog entry          (hash-chained)
                    '- finalizeCase()
                         |- evaluatePlaybooksForCase()   (synchronous)
                         '- enrichCaseIndicators()       (after(): VirusTotal / AbuseIPDB)
```

4.4 Data model

39 Prisma models across 11 migrations. The main groups:

Group	Tables
Identity and access	User, Account, Session, ApiToken, Tenant, ServicePlan
Cases	Case, TimelineEntry, Detection, CaseComment, CaseWatcher, Notification
Telemetry and intel	SecurityEvent (one telemetry table for SIEM and investigations), ThreatIndicator, CaseIndicator, ThreatFeed
ATT&CK	MitreTactic, MitreTechnique, CaseMitreTechnique
Response	Playbook, PlaybookAction, PlaybookExecution, PlaybookApproval, ResponseAction
AI	AiProvider, AiAgentProfile, AiRun, Agent (governed agents)
Tools and assets	Integration, IntegrationAssignment, Endpoint (with asset class and type), CatalogTool
Commercial	Quote, PriceItem, VolumeDiscount, Currency, AiModelPrice
Platform	PlatformSetting, AuditLog

4.5 Reference data in the database

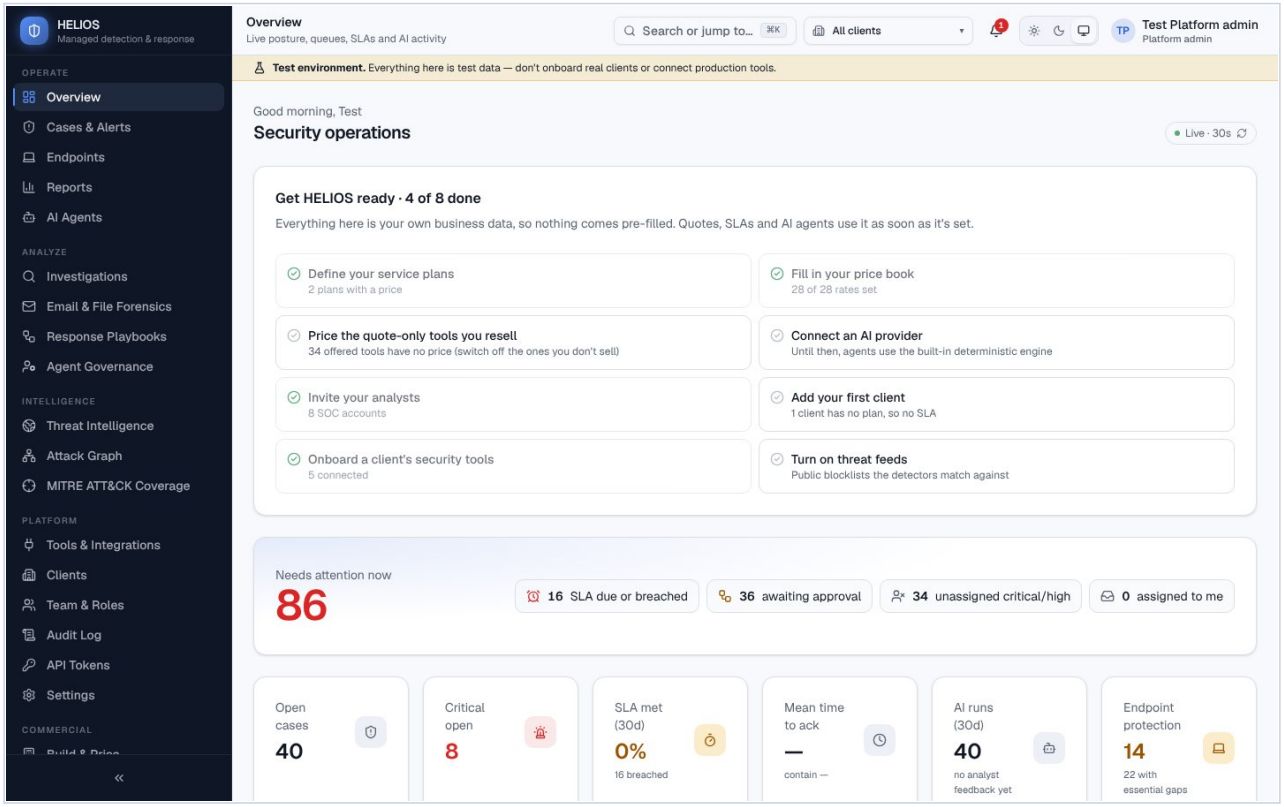
Plans, the price book, the tool catalog, currencies, model prices and threat feeds are tables, not constants. The code describes only their shape: price items without values, and the tool taxonomy. Company policy is entered by the admin, so the same build serves any MSSP.

5. Security operations modules

Every screenshot in this section is from the running application, in a test environment with labelled test data.

5.1 Overview

A role-aware dashboard. Admins see the first-run setup checklist (plans, price book, AI provider, first client, tools, threat feeds), plus what needs attention: SLA breaches, cases awaiting approval, unassigned critical cases and the user's own queue. Live tiles show open and critical cases, SLA performance, mean time to acknowledge, AI runs and endpoint protection. A command palette (Ctrl+K) jumps to anything.

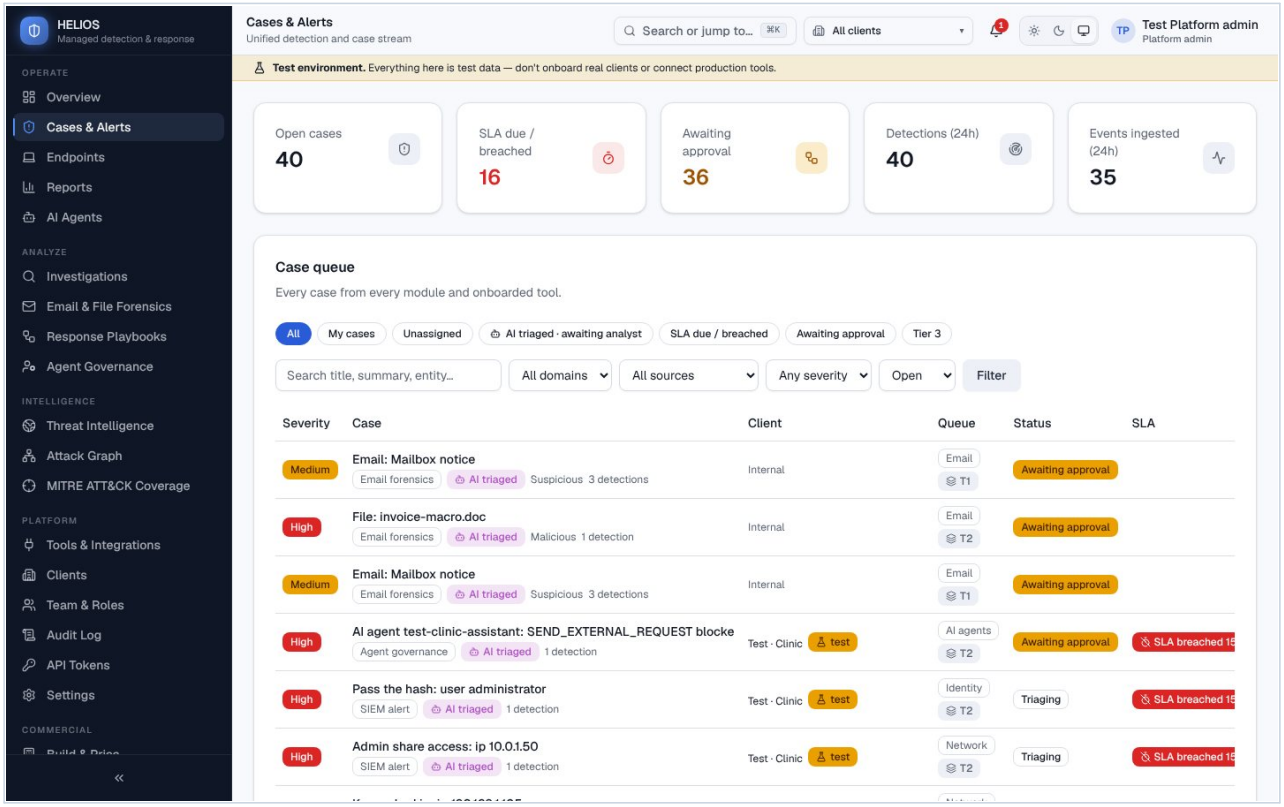


Overview: setup checklist, attention panel and live tiles.

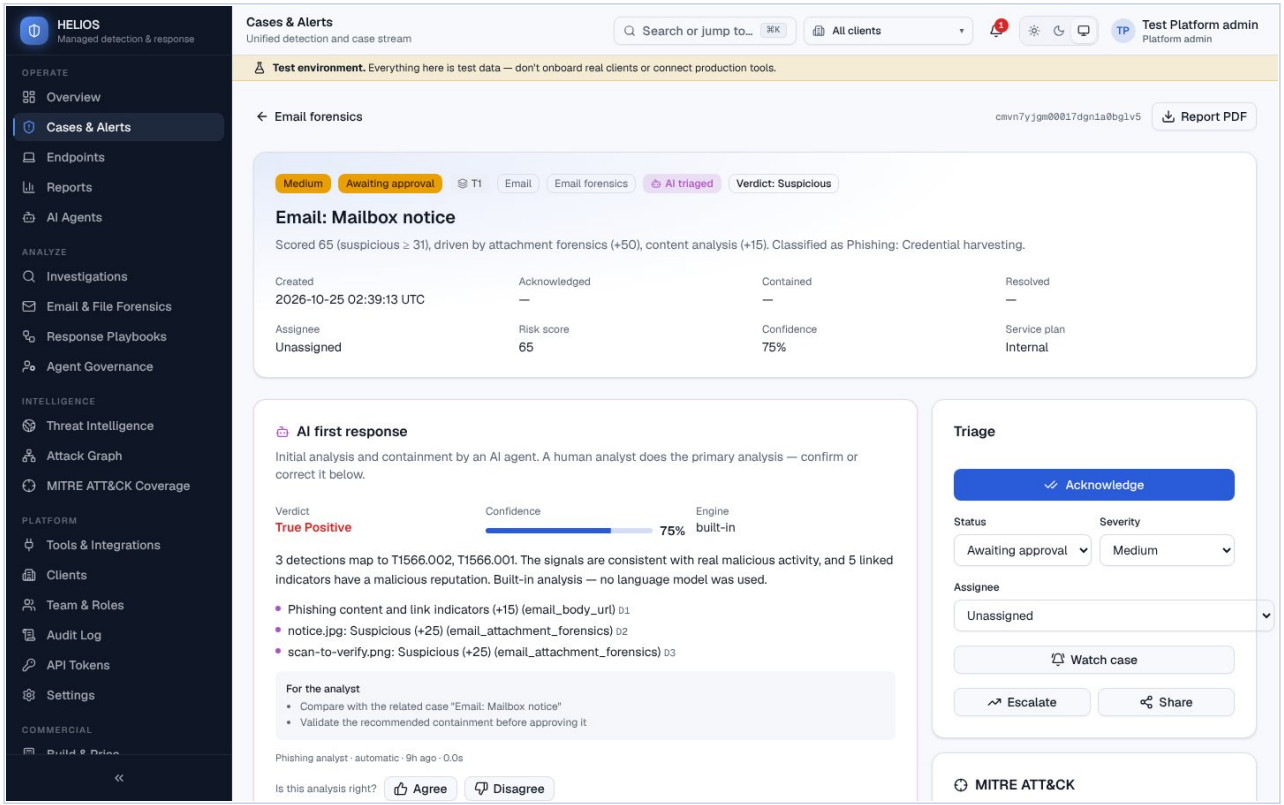
5.2 Cases & Alerts

1. **Ingest.** Four adapters (auth, endpoint, network, cloud) normalise raw logs into SecurityEvent rows. Vendor alerts arrive on per-tool ingest URLs and are mapped from each vendor's own payload.
2. **Detect.** 11 detectors run over the batch plus the previous 24 hours, so multi-event rules (password spraying, impossible travel, attack chains, port scans) can span ingests.
3. **Score.** Confidence × signal-family multiplier, capped at 1000, mapped to a severity.
4. **De-duplicate.** Each detection is fingerprinted, so a finding already on file is never re-filed. The legacy SIEM re-filed everything on every run.
5. **Correlate.** New detections join an open case for the same user, host or IP from the last 24 hours, and severity only ratchets up. Otherwise a new case opens.

The queue offers tier-1/2/3 escalation, assignment, watchers, @mentions, internal or client-visible discussion, SLA clocks from the client's plan, and filters by domain, source, severity and SLA.



Case queue across every source, with SLA state, AI triage badges and client.

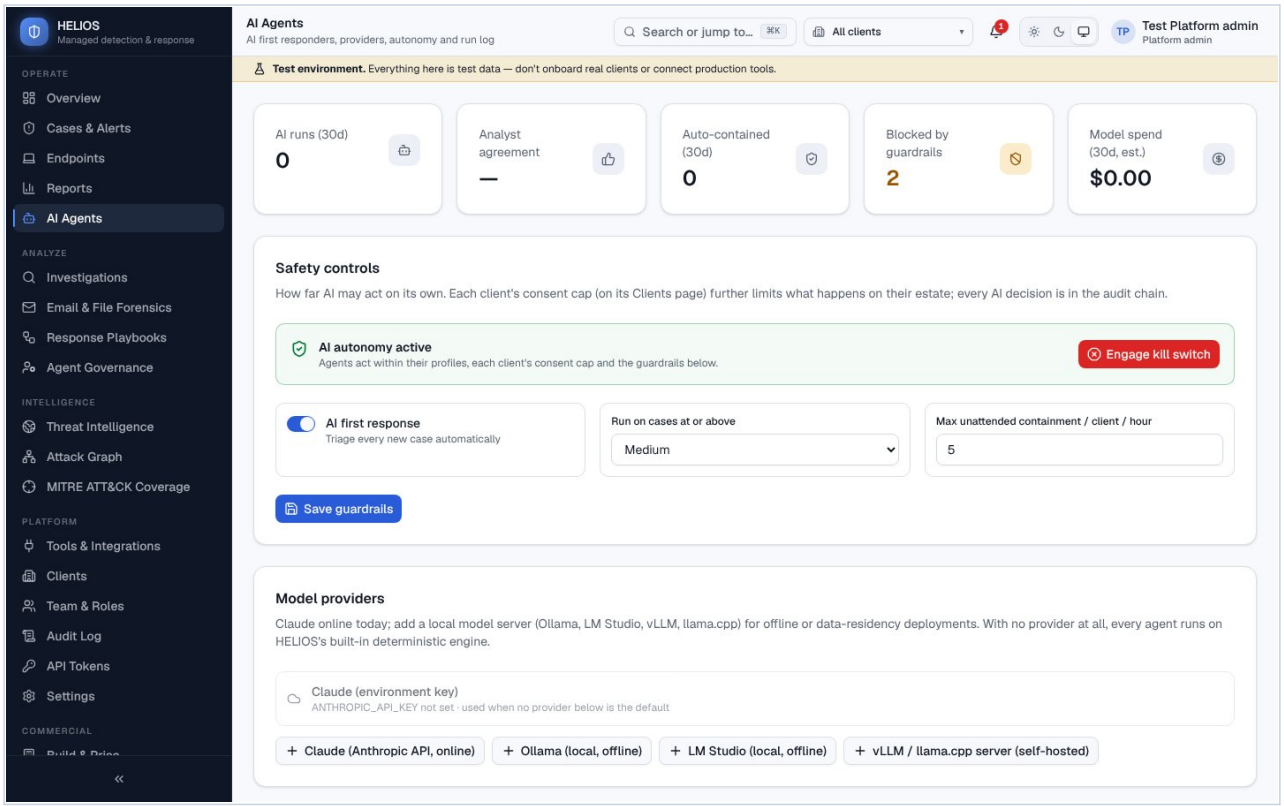


A case: AI first response with verdict, confidence and cited evidence; triage, escalation and sharing.

5.3 AI first responder and response actions

1. **Schedule.** New cases at or above a configured severity are queued, with a concurrency limit.
2. **Evidence.** The case is rendered into numbered evidence (at most 80 events, worst first), which the agent must cite.
3. **Ground.** Claims and action targets that aren't in the evidence are rejected.
4. **Provider.** The engine is chosen per agent profile: Claude, a local OpenAI-compatible model, or the built-in deterministic engine.
5. **Decide.** The pure response policy returns SUGGESTED, PENDING_APPROVAL, EXECUTED or BLOCKED.

There are seven agent types: the triage first responder, containment controller, phishing analyst, threat-intel enricher, client report writer, investigation swarm and stack advisor. Each has its own provider, model, autonomy, allowed actions, confidence bar and instructions. The response executor is the only place an action happens. It handles isolating and releasing hosts, blocking and unblocking IPs, killing processes, quarantining files, disabling and re-enabling accounts, blocking senders, collecting logs, creating tickets, notifying channels, and revoking and restoring AI agents. Effects on client systems go through a signed webhook to the client's response connector; every action can be rolled back.

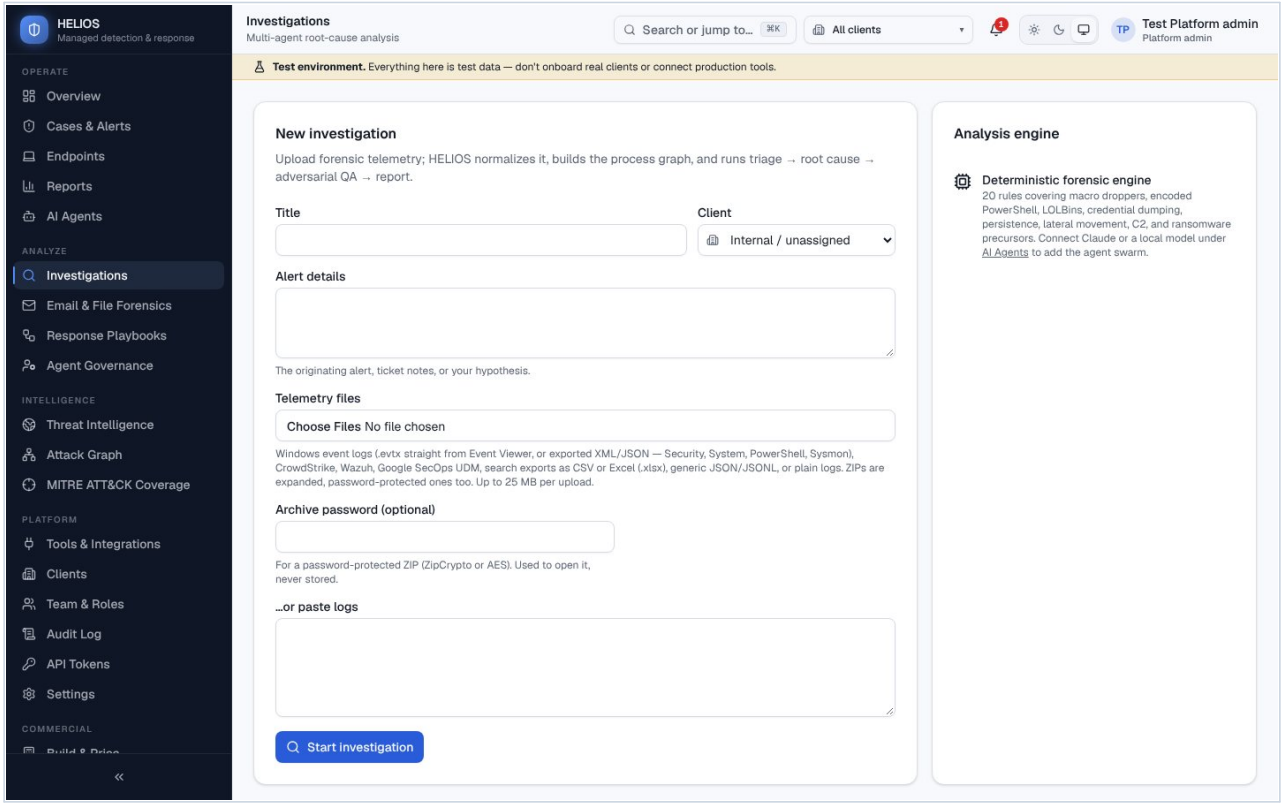


AI Agents: safety controls (kill switch, severity threshold, rate limit) and model providers.

5.4 Investigations

Analysts upload Windows .evtx straight from Event Viewer, or Sysmon, EDR and SIEM exports as JSON, CSV or Excel .xlsx. ZIPs are accepted too, including password-protected ZipCrypto and WinZip AES archives with checked CRC and HMAC. A dependency-free BinXML reader parses .evtx. Events are normalised to one schema, and Windows providers are mapped: Sysmon, Security auditing, Service Control Manager, PowerShell and Task Scheduler.

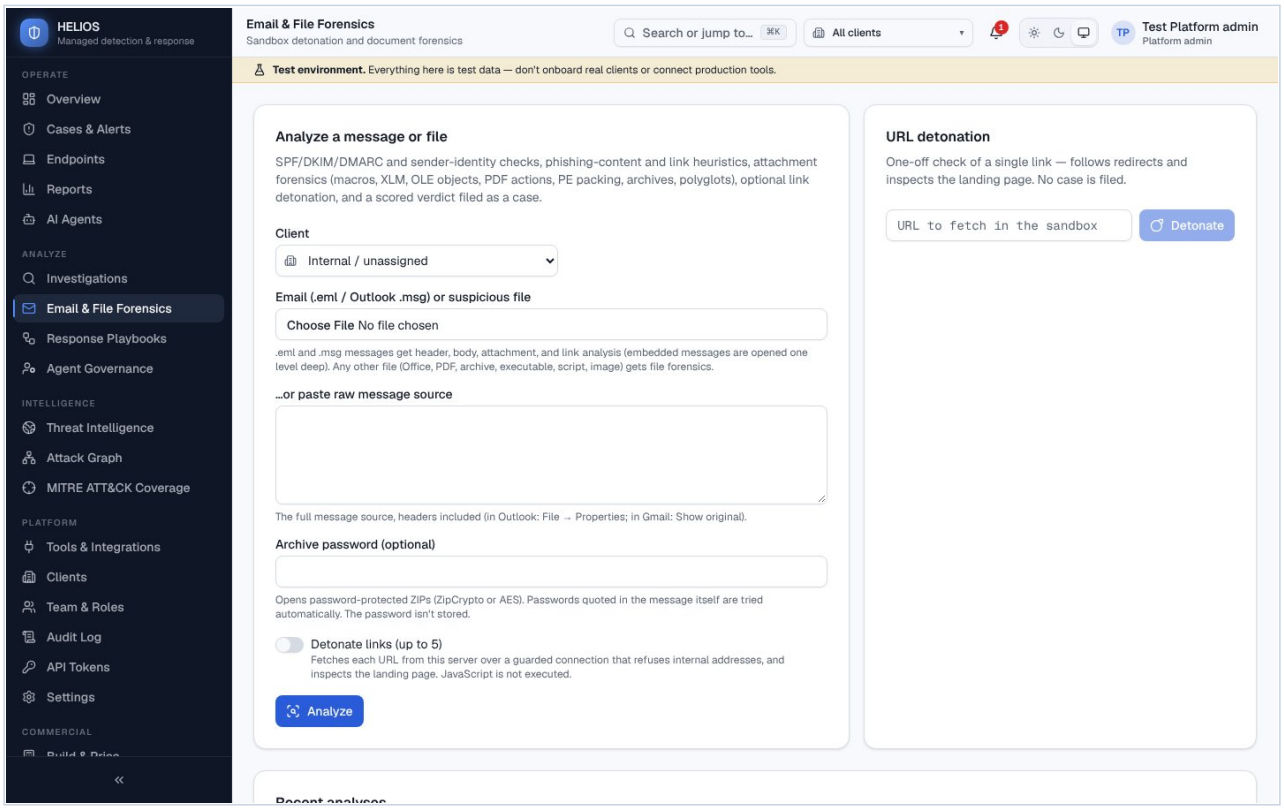
The pipeline builds an entity graph (process lineage, network, DNS, files), runs the deterministic forensic rules, then triage, root cause and QA. Root cause is rebuilt with QA's objections, up to three rounds, before the report. Each stage is a grounded Claude call with structured output when a key is configured. A failed stage falls back to the deterministic engine and records a note, and mechanical QA checks (timestamps exist, no process connects out before it was created) always run.



Investigations: upload or paste telemetry; the analysis engine in use is shown.

5.5 Email & file forensics

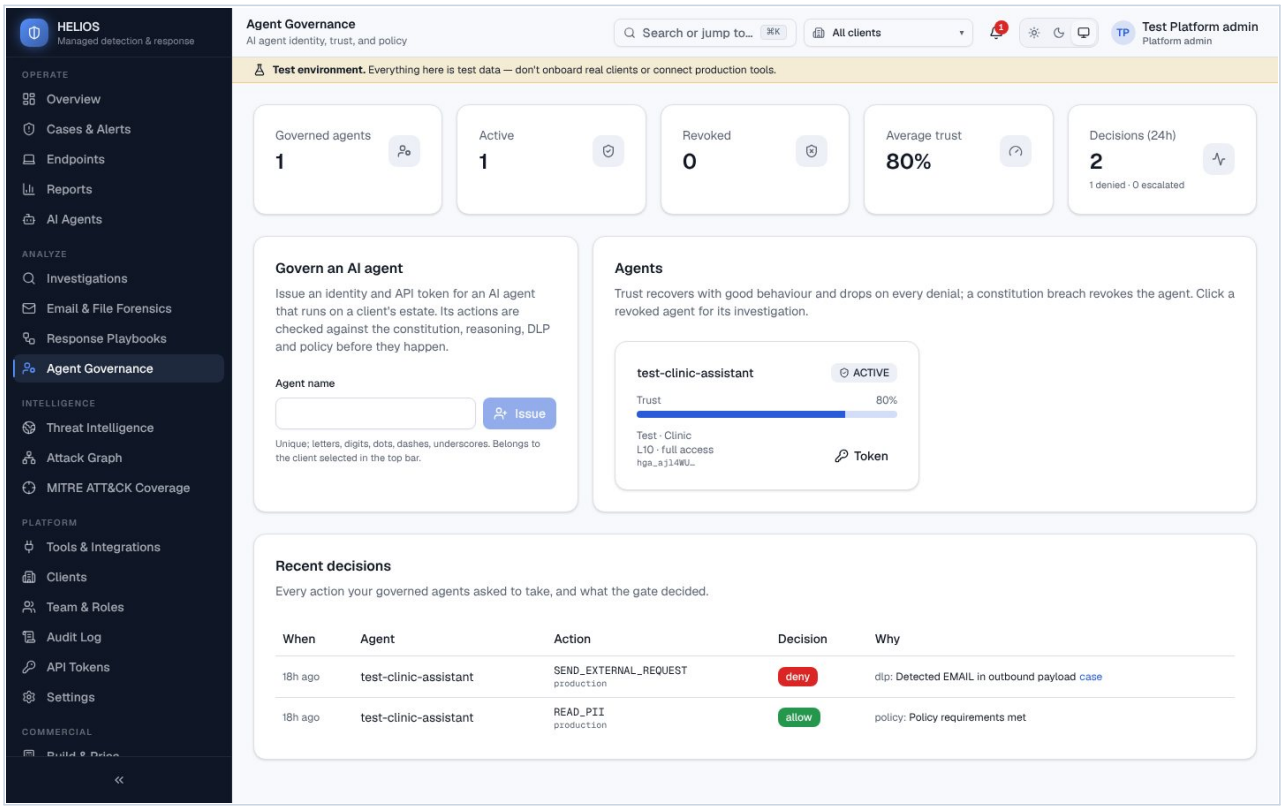
- **Headers:** SPF, DKIM, DMARC and TLS; Reply-To and Return-Path mismatches; the hop trace; optional DMARC lookups and MxToolbox diagnostics.
- **Body:** lure language, links (Proofpoint and Safe Links unwrapped), look-alike brands, raw-IP links, TOAD, and HTML forms, password fields, hidden posts and obfuscated JavaScript.
- **Attachments, read from the bytes:** archives (including encrypted ones, opened with the analyst's password or one quoted in the message), Office macros with VBA source recovered by a Compound File and MS-OVBA reader, XLM, remote templates, PDF actions, PE sections and entropy, and masquerading.
- **Images:** QR codes are decoded and printed text is read with OCR. A message whose words exist only in a picture is flagged.
- **Detonation** (opt-in, up to 5 links): an HTTP-level fetch with an SSRF guard, through an egress proxy if configured, scored on credential capture, off-domain targets and stealth.
- **Verdict:** a point model (malicious ≥ 71, suspicious ≥ 31, adjustable) with a classification, explanation and block recommendations.



Email & File Forensics: .eml, .msg or any file; archive password; optional link detonation.

5.6 Agent governance

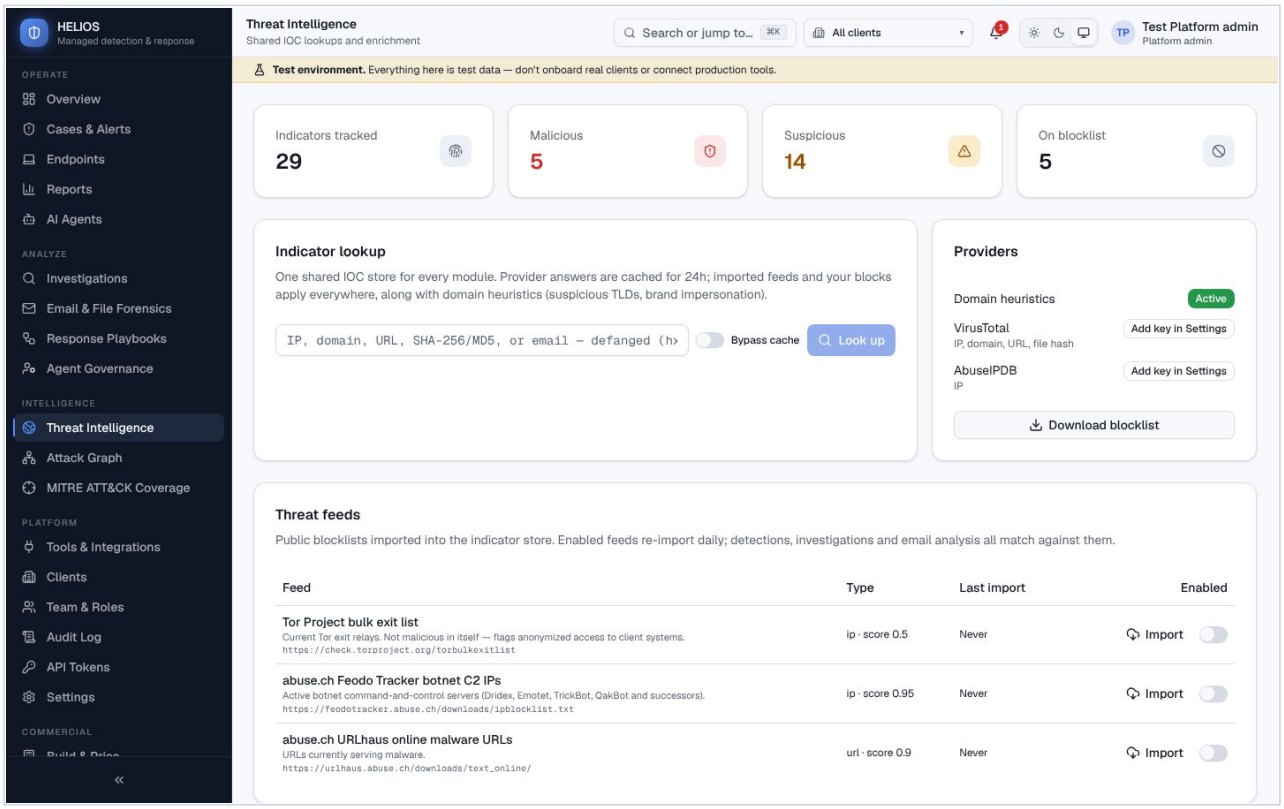
This module governs the AI agents that clients run. Before acting, an agent calls POST /api/governance/evaluate with its token. Four checks decide: the constitution, reasoning drift, a DLP and prompt-injection firewall, and intent policy. Trust recovers slowly on allow and drops on deny or escalation. Below a floor, even allowed actions escalate to a human. A constitution breach revokes the agent at once and opens a contained case.



Agent Governance: governed agents, trust, tokens and recent decisions.

5.7 Threat intelligence

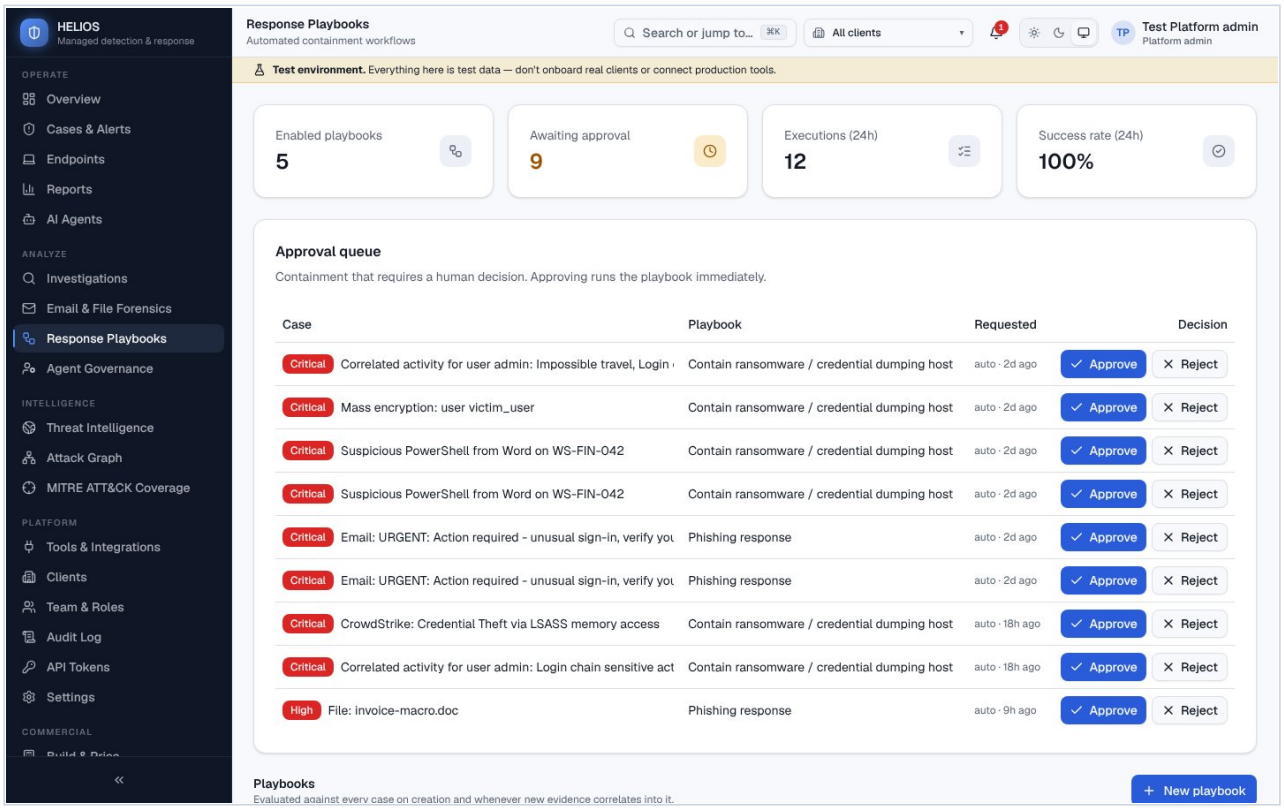
A shared indicator store for every module. Indicators are extracted from free text (refanged, with private IPs and filename false positives dropped). Public blocklists can be imported: the Tor exit list and the abuse.ch Feodo and URLhaus feeds, re-imported daily. VirusTotal and AbuseIPDB lookups are cached for 24 hours. Blocks are served as a plain-text blocklist feed. Nothing is malicious unless a feed, a provider or a block says so.



Threat Intelligence: indicator lookup, providers, store and public feeds.

5.8 Response playbooks

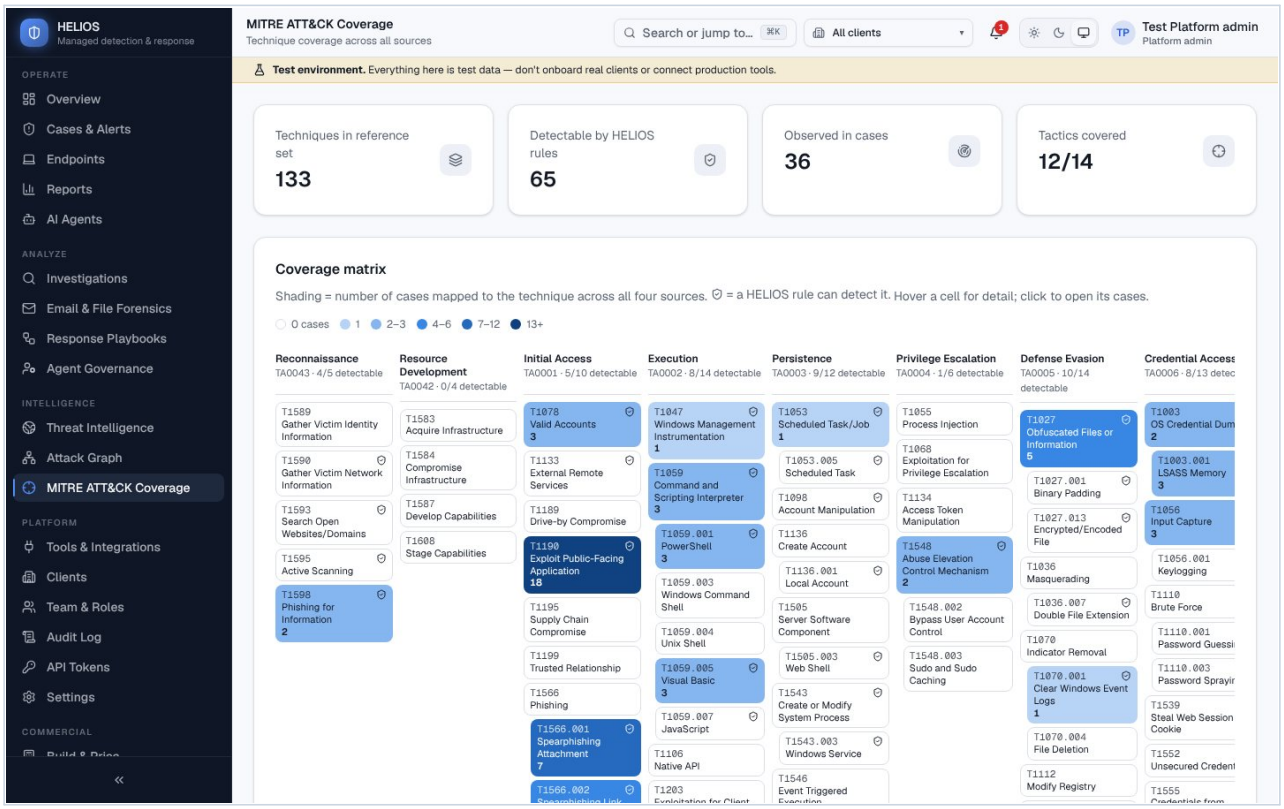
Each playbook has a validated trigger, which can match on severity, case source, ATT&CK technique (a parent ID matches its sub-techniques), detection source, risk score or verdict. A playbook runs automatically, waits in an approval queue, or is offered as a suggestion, at most once per case. Recommendations score every playbook against a case and show their reasons. Steps run through the same executor as every other action; a step with nothing to carry it out is reported as one to do by hand.



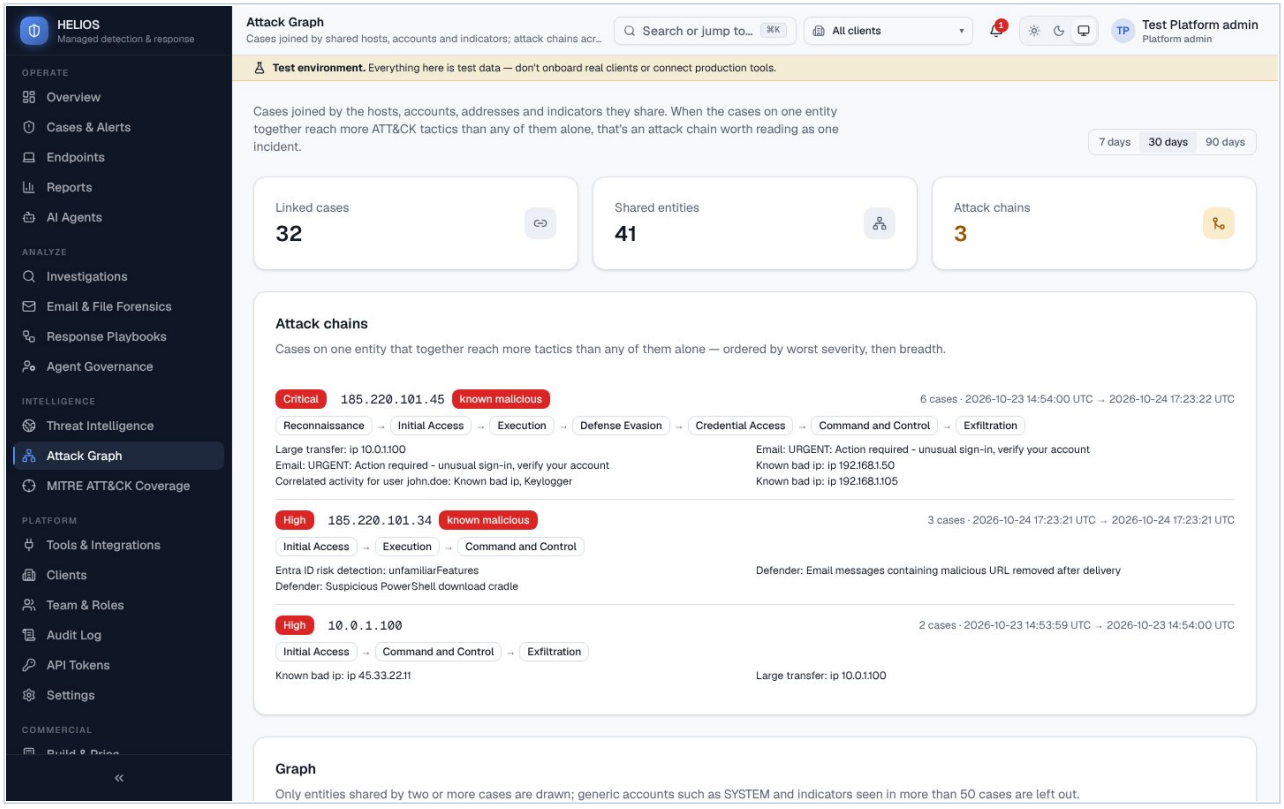
Response Playbooks: approval queue and playbooks with their triggers.

5.9 ATT&CK coverage and the attack graph

The ATT&CK catalog holds 14 tactics and 133 techniques. The "detectable" layer comes from every module's rule registry, currently 65 techniques across 12 tactics; detectors can be switched off. The "observed" layer comes from real cases. The attack graph links cases that share hosts, accounts, addresses, indicators or agents, leaving out generic accounts and noisy indicators. An entity is flagged as an attack chain only when its cases together reach more tactics than any one case alone.



MITRE ATT&CK coverage matrix: detectable vs observed techniques.

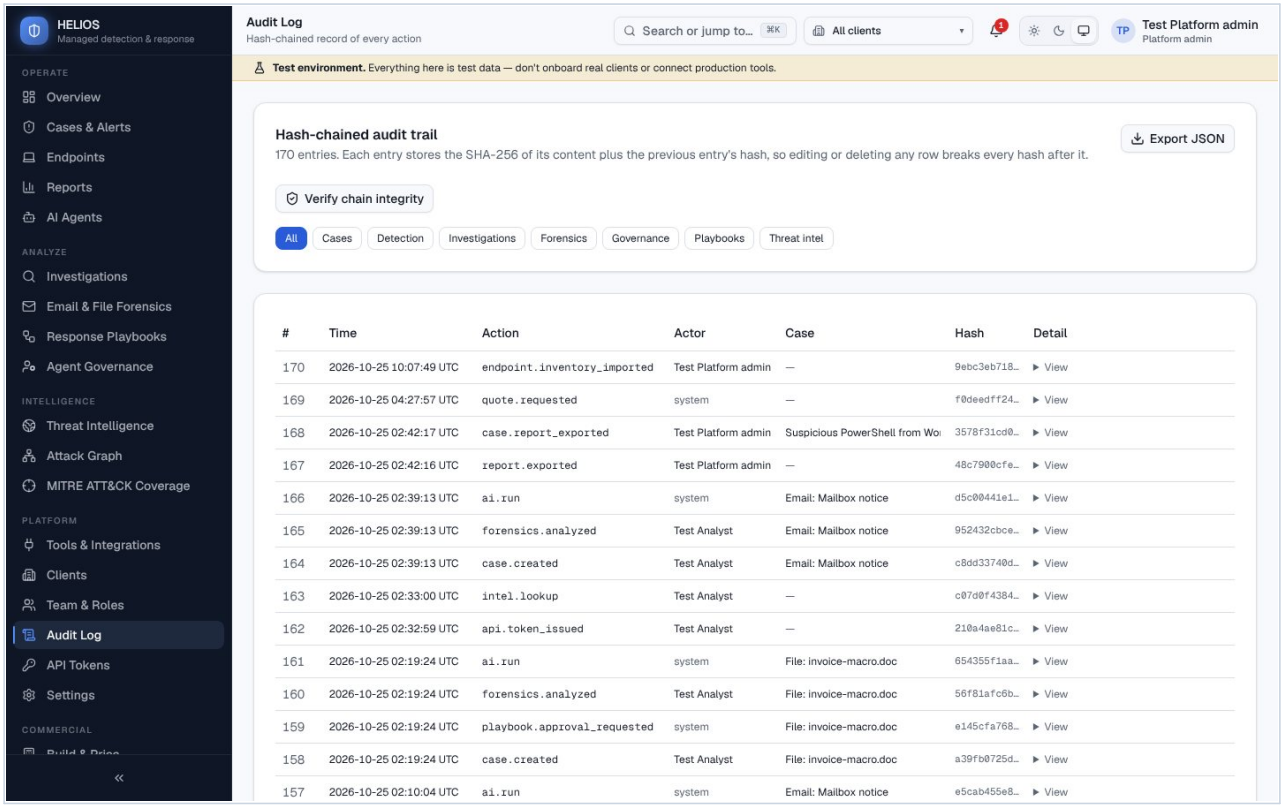


Attack Graph: entities whose cases together form an attack chain across tactics.

5.10 Audit log

Each entry hashes its actor, case, action, detail and the previous hash as canonical JSON. A sequence number fixes the order. Appends take a Postgres advisory lock so concurrent writers

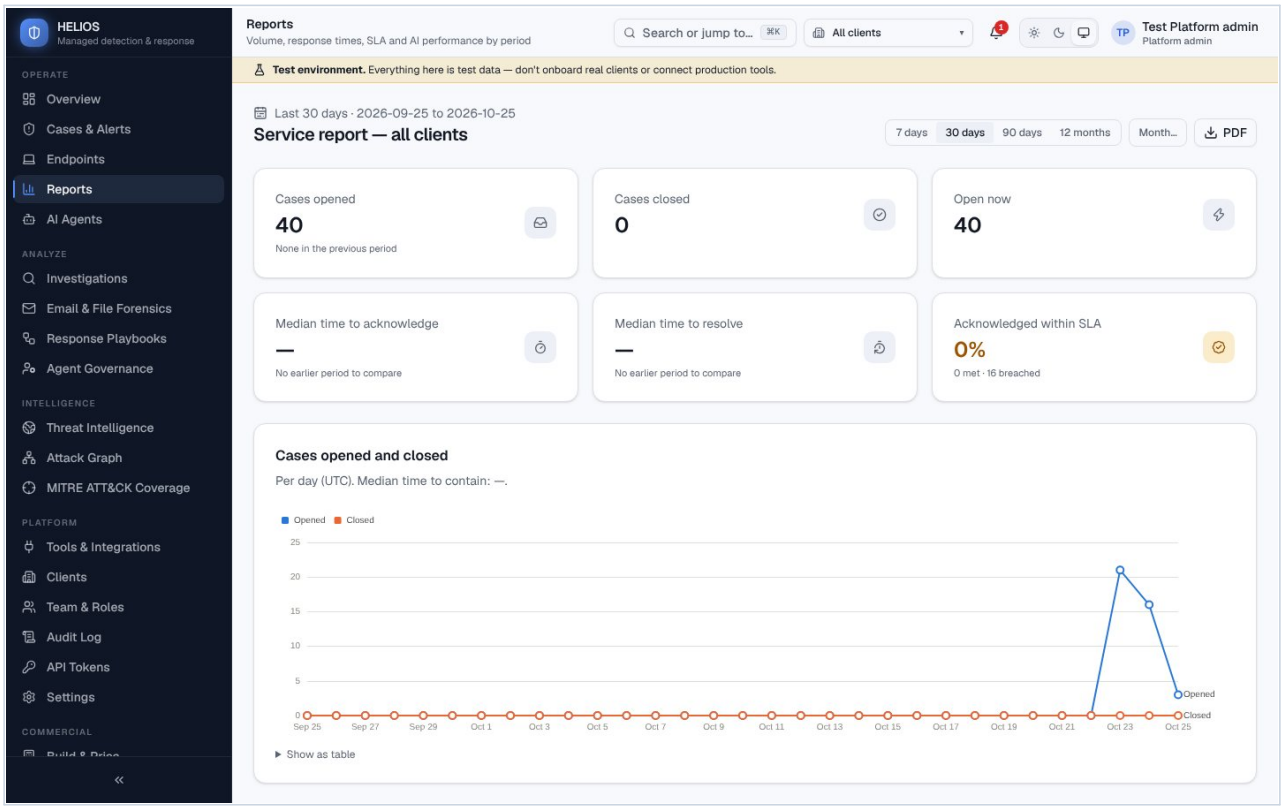
can't fork the chain, and foreign keys are RESTRICT so deletions can't null hashed columns. The verifier reports the first broken entry and whether its content or its link was altered.



Audit Log: the hash-chained trail with integrity verification and JSON export.

5.11 Reports and PDFs

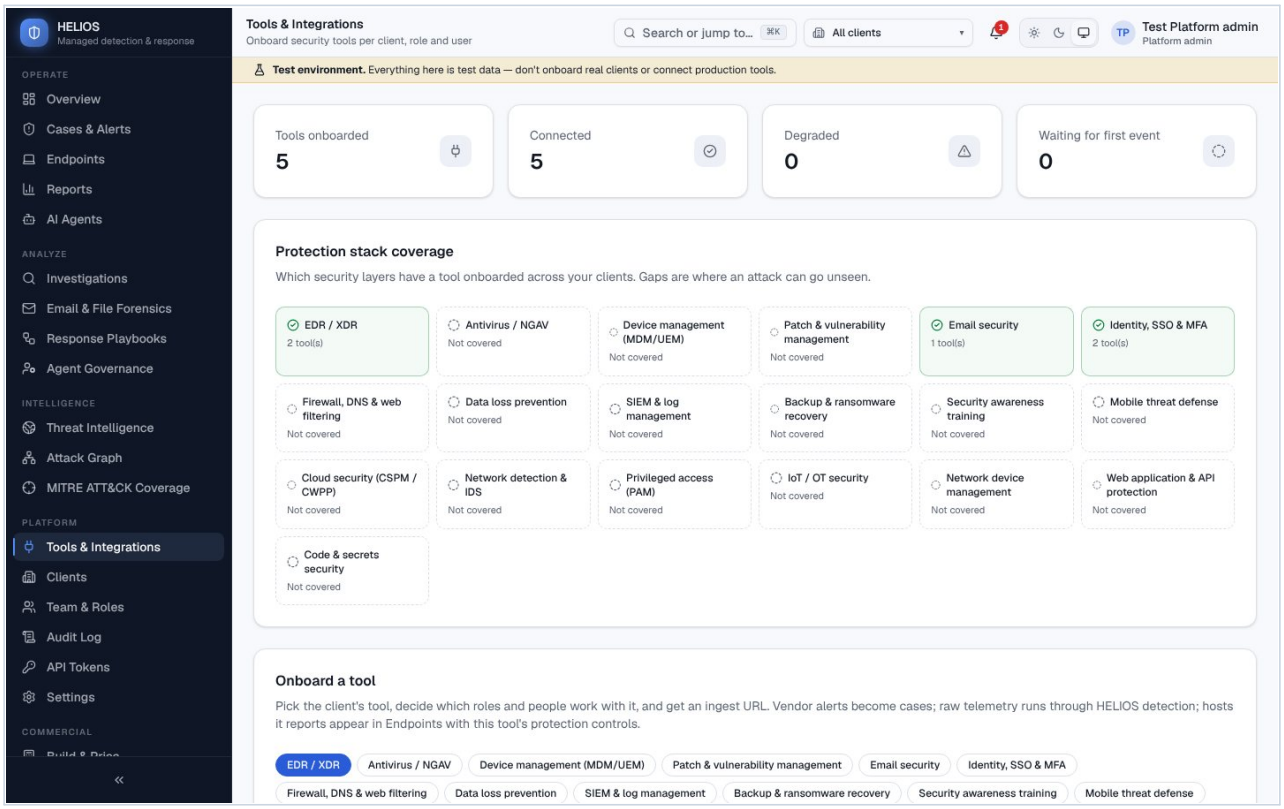
Reports cover case volume, median time to acknowledge, contain and resolve, acknowledge-SLA compliance, the mix by severity, source, domain and client, top techniques and indicators, AI runs and analyst agreement, containment outcomes and workload. Each is compared with the previous period. Clients get their own view. The service report, incident reports and quotes download as PDFs. Client copies leave out AI working notes, and quotes never carry cost or margin.



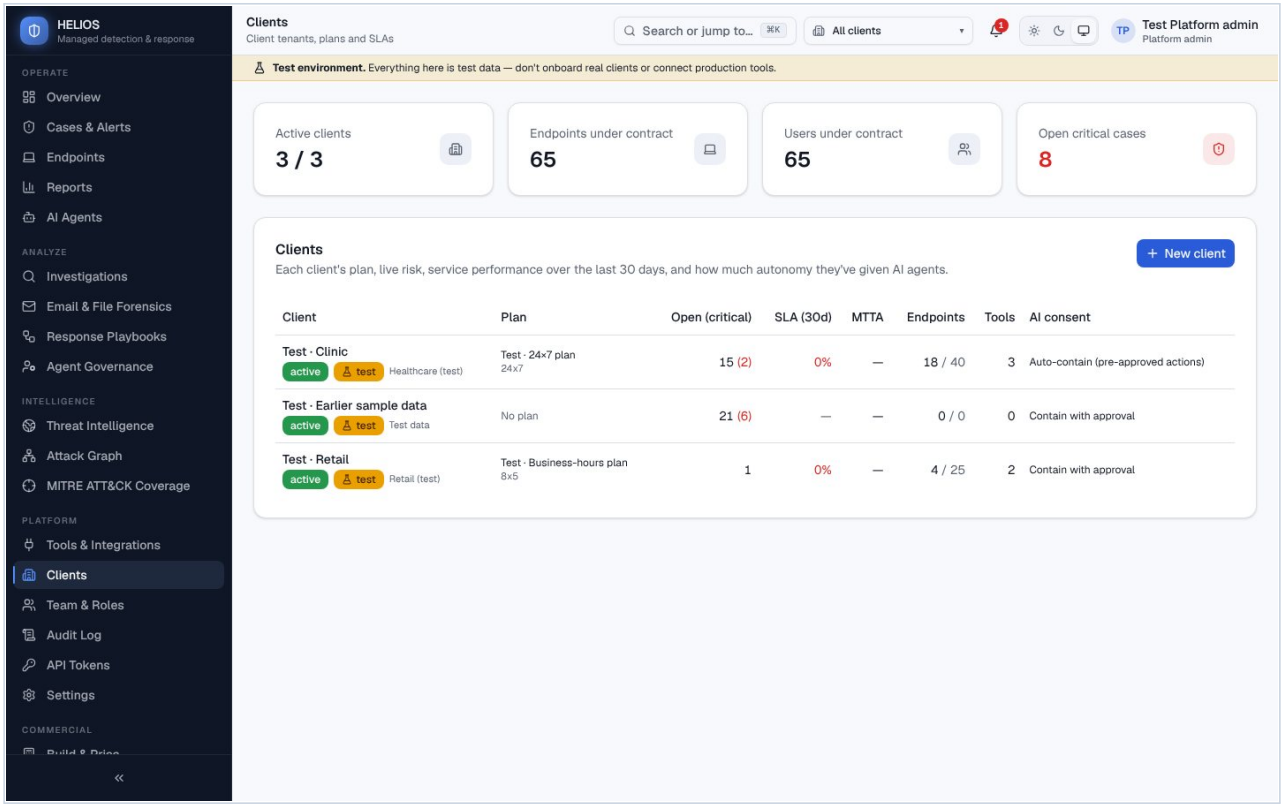
Reports: service report for any period, compared with the period before; PDF download.

5.12 Clients, team, tools and endpoints

- **Clients:** plan, risk, SLA performance, AI consent, and live-stack and upgrade review links.
- **Team & Roles:** invite users, assign roles and domain queues, lock and unlock accounts.
- **Tools & Integrations:** onboard each client's tools from the catalog. Each gets an ingest URL with a once-shown token, and tools can be assigned per role or person. A coverage panel shows which protection layers are missing.
- **Endpoints:** the asset inventory, filed by asset group and type, with the protection each onboarded tool provides, isolation status and missing essential controls.



Tools & Integrations: protection stack coverage across every layer, and onboarding.



Clients: plans, open and critical cases, SLA, endpoints, tools and AI consent.

5.13 Settings, REST API and the installable app

Settings hold the environment (production or test), the company profile, sealed provider keys, forensics thresholds, trusted link domains and the public website switches. REST API v1 (cases,

comments, indicators, metrics, me) uses personal access tokens that act as their owner: read-only unless created with write, optionally expiring, rate-limited to 300 requests a minute, and audited. A web app manifest and icons make HELIOS installable as a desktop or mobile app with shortcuts, replacing DESAS's desktop shell.

6. The whole attack surface

Security isn't only laptops. Following the enterprise endpoint taxonomy, HELIOS models nine asset groups. For each one it records what the group includes, its main risk, what to deploy (required, recommended and advanced), the telemetry to collect, what the SOC detects and how it responds. Quotes count every group, the inventory files every asset under one, and the advisor, coverage score and designer all reason about them.

Asset group		Includes	Main risk	Required (+ recommended)
User endpoints	P1	Laptops, desktops, BYOD, admin workstations, VDI, kiosks	Malware, ransomware, phishing	EDR, AV, host firewall, disk encryption, patching, MDM, app control
Mobile endpoints	P2	Android and iOS phones, tablets, BYOD	Lost devices, malicious apps, SMS phishing	MDM, MFA (+ MTD)
Servers & infrastructure	P1	Windows and Linux servers, domain controllers, DNS/DHCP, file, database and web servers, hypervisors, backups	Business disruption, data loss	EDR, patching, vulnerability scanning, backup (+ PAM, firewall)
Cloud & workloads	P2	AWS, Azure, Google Cloud, Kubernetes, serverless, SaaS	Misconfiguration, data exposure	CSPM, CWPP (+ SSPM)
Network & security devices	P2	Firewalls, VPNs, routers, switches, access points, proxies	Unauthorised access, lateral movement	Device management, central logging (+ NDR)
Identity & access	P1	Active Directory, Entra ID, Okta, PAM, MFA systems	Account takeover, privilege escalation	MFA, ITDR (+ PAM)
IoT & OT	P3	CCTV, printers, PLCs, SCADA/HMI, medical and building systems	Exploitation, operational disruption	IoT/OT monitoring (+ NDR)
Email & collaboration	P1	Exchange, Microsoft 365, Gmail, Teams, Slack, browsers	Phishing, business email compromise	Email protection, MFA (+ web filtering)
Applications, APIs & developer systems	P2	Websites, portals, APIs, repositories, CI/CD runners	Code compromise, secrets theft, app attacks	WAF, code & secrets security (+ API security)

6.1 Priorities that move with the organisation

Groups start from the usual order: devices, critical servers, identities and email are P1; cloud, network, mobile and apps are P2; IoT/OT is P3. They then move with the organisation, and the reason is shown each time:

Condition	Effect	Reason shown
Cloud-first environment	Cloud → P1	The business runs on cloud workloads and SaaS
On-premises first	Cloud → P3	Little runs in the cloud
Industrial / OT-heavy, or healthcare, manufacturing, energy	IoT & OT → P1	Medical devices affect patient safety; production depends on OT; critical infrastructure runs on OT
Technology company	Apps → P1	Source code and online services are the product
Finance, or a regulated company	Apps → P1	Regulators expect secure internet-facing applications

Condition	Effect	Reason shown
Retail and e-commerce	Apps → P1	Online sales depend on internet-facing applications
Large enterprise	Network → P1	A large network makes lateral movement the main risk

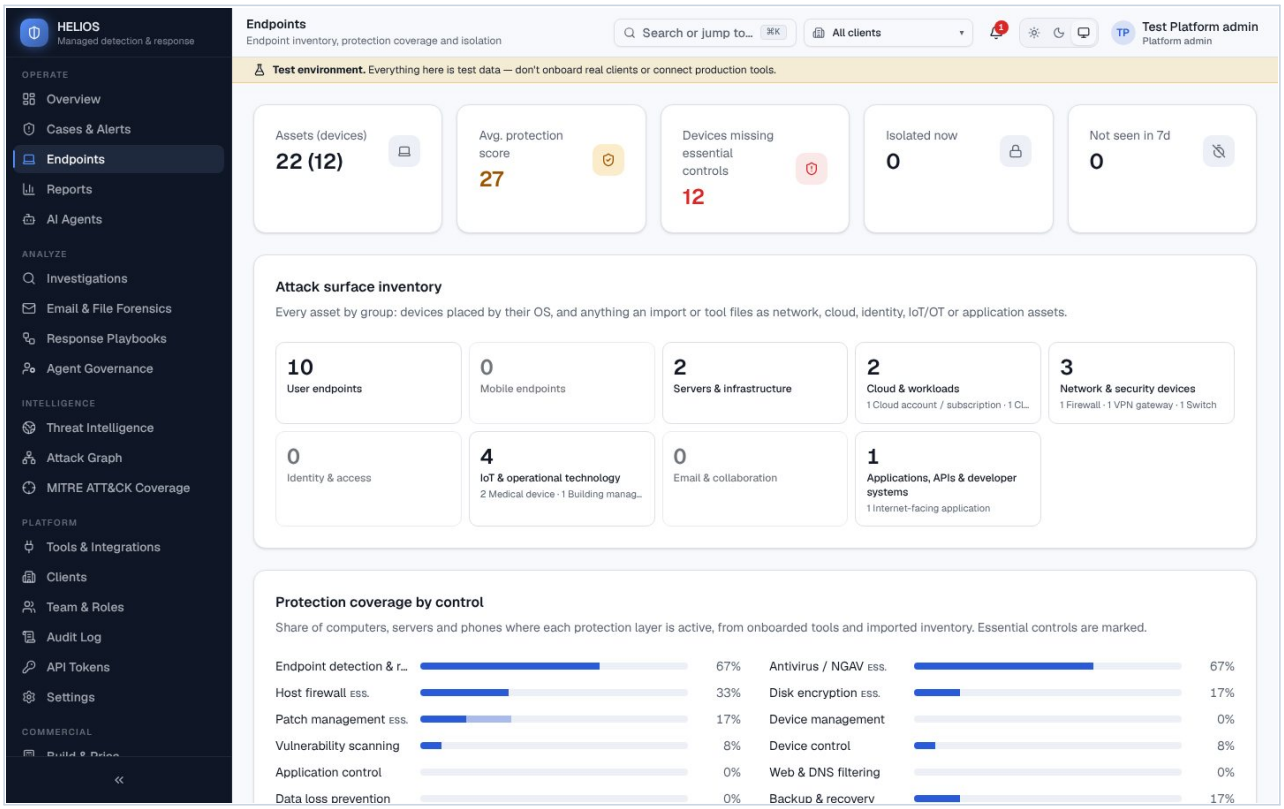
6.2 28 capabilities

Twelve per-device controls (EDR, antivirus, host firewall, disk encryption, patching, MDM, application control, web and DNS filtering, vulnerability scanning, backup, DLP, device control) plus sixteen for the rest of the surface:

Capability	What it covers
MTD	Malicious apps, phishing and risky networks on phones and tablets
MFA & conditional access	Strong sign-in, device-compliance and location rules for every account
ITDR	Account takeover, password spraying, Kerberoasting and DCSync
PAM	Vaulted admin credentials, just-in-time elevation, recorded privileged sessions
Email protection	Phishing, business email compromise, malicious attachments and links
CSPM / CWPP / SSPM	Cloud posture; runtime protection for VMs, containers and Kubernetes; SaaS settings and OAuth apps
NDR & network device management	Intrusion detection and traffic analysis; config changes, firmware and admin access on network gear
IoT / OT monitoring	Passive discovery and threat detection for PLCs, SCADA, medical and building systems
WAF / API security / code security	Web app attacks; API discovery and abuse; SAST, dependency and secrets scanning
SIEM / SOAR	Provided by HELIOS itself: central correlation into cases, and automated response playbooks

6.3 The inventory by asset group

Every asset carries a class and a type (laptop, VDI, domain controller, firewall, PLC, medical device, cloud VM, repository…). Rows without a class are placed by their OS. Only computers, servers and phones get device controls and count in the endpoint mix. The rest become estate counts, so a client's real inventory sizes their quote.



Endpoints: the attack-surface inventory by group, and protection coverage by control.

7. Build & Price

The configurator designs and prices the service for a client or a prospect. It has six tabs: Build, Design, Upgrades, Advisor, Compare and Line items. It estimates monthly, annual, one-time, maintenance (AMC) and 3-year cost, with cloud-versus-local AI, margins and multi-currency, and saves versioned quotes that download as PDFs.

7.1 The calculator

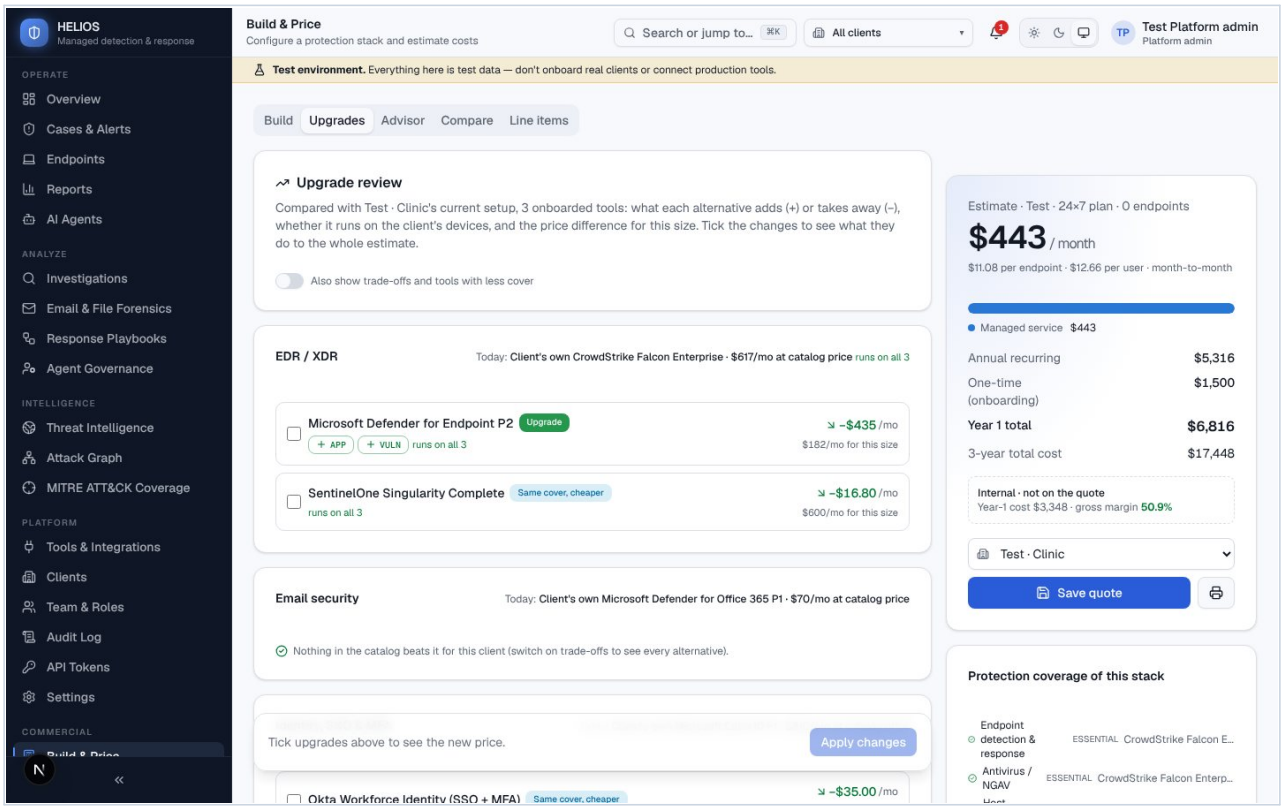
- **Sizing:** the endpoint mix by OS (Windows, macOS and Linux desktops and servers, iOS, Android, unknown), users and mailboxes, log volume, and the estate: cloud accounts and workloads, SaaS platforms, network devices, privileged accounts, IoT and OT devices, internet-facing apps and developers.
- **Managed service:** the plan's per-endpoint price plus per-asset monitoring for every group, from the price book (server, identity, cloud account, workload, SaaS, network, IoT, OT and application monitoring).
- **Tools:** one per protection layer, licensed per endpoint, user, server, workload, account, device, app, developer or privileged account. Volume discounts apply, and the client's own licences are recorded as theirs.
- **AI:** cloud model usage from Anthropic's published prices with a platform fee and markup, or local GPU hardware with hosting, setup and AMC.
- **Terms:** annual and 3-year discounts, tax and exchange rate. Internal cost and margin are shown only to staff.

7.2 Platform fit

Each tool lists the platforms it runs on. The fit checks which of the client's machines a tool actually covers, so an EDR without macOS support is flagged on a Mac-heavy estate. SaaS-only tools (for example, a Microsoft 365 backup) don't count as protecting devices.

7.3 Upgrade review

This compares each layer's current tool (the quote's, or the client's own) with every alternative: capabilities gained or lost (separating losses another layer still covers), the change in platform fit, alerts and response actions, and the price difference. Each option is classified as an **upgrade**, **cheaper**, a **trade-off**, **equivalent** or a **downgrade**. Ticked changes are priced on the whole quote, including onboarding, discounts and essential gaps closed or opened. For an existing client, the baseline is their live stack: the accepted quote (the contract) or their plan, sized from the inventory, with every onboarded tool recorded as theirs.



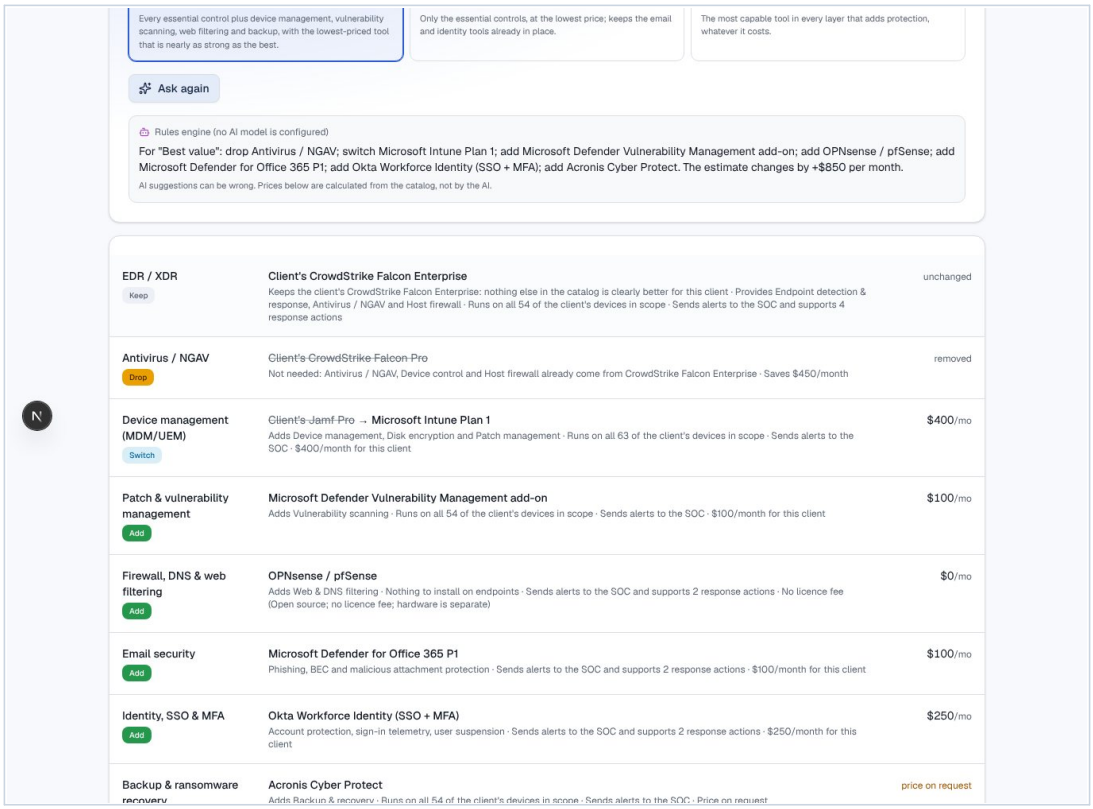
Upgrade review in the console, against a client's live stack.

7.4 Stack advisor: rules first, AI on top

The rules decide layers from broadest to narrowest, so an EDR that includes antivirus makes the antivirus layer unnecessary. Each tool is scored on the capabilities it adds that the goal wants, weighted by the priority of the asset groups they protect and by platform reach. Then the goal picks:

Goal	What it covers	How it picks
Lowest cost	What the P1 groups require	The cheapest tool that covers the essentials
Best value	Every group's requirements, plus the P1 groups' recommendations	The cheapest tool within 75% of the best score
Strongest protection	Every required, recommended and advanced capability	The highest score

A current tool that's nearly as good (≥ 0.75 of the best) is kept, and a client's own SIEM is kept because HELIOS ingests its alerts. The AI advisor receives only the candidates the rules priced and picks one per layer. Picks outside the list are discarded in favour of the rules' pick, prices are always recalculated, and the run is logged. With no model, or once the website's daily AI budget is spent, the rules answer.



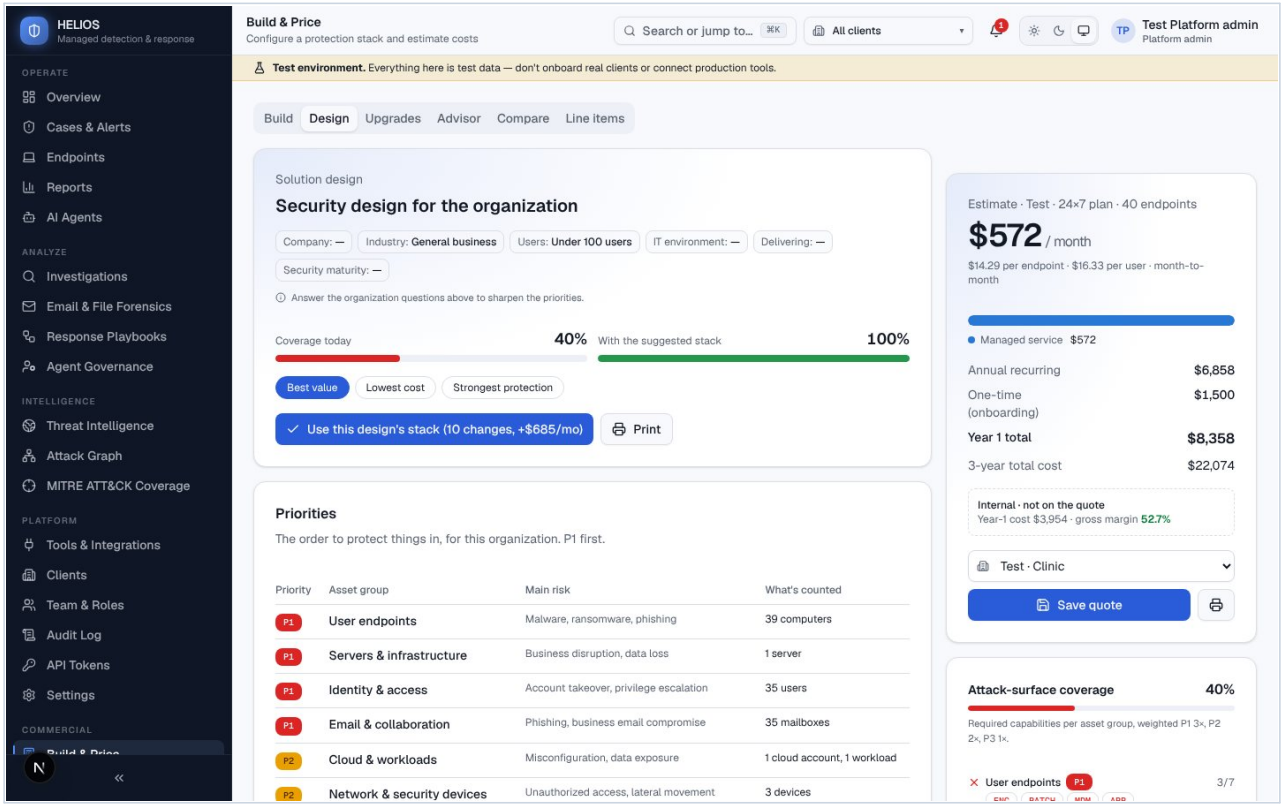
The advisor's picks with reasons and the price difference (rules engine shown).

7.5 Solution designer

This answers "design my cybersecurity solution" from the organisation's answers (company type, industry, environment, users, maturity and what's being delivered). It produces:

- **Priorities:** every asset group with its P1–P3 priority, main risk, what's counted, and why it moved.
- **What to deploy per group:** each required and recommended capability, shown as in place, suggested by the advisor, or a gap; plus telemetry, detections and response.
- **Architecture:** five layers, from assets to telemetry to the central platform (HELIOS) to detection to response, filled in with the client's actual tools.
- **Rollout:** phase 1 for P1 groups, phase 2 for P2 groups, phase 3 for P3 groups, then hunting and tuning.
- **Guidance** by maturity and scope. An endpoint-only delivery keeps the other groups for later phases.

A coverage score (required capabilities covered, weighted by priority) shows the current stack against the suggested one. One click applies the design's stack to the quote.



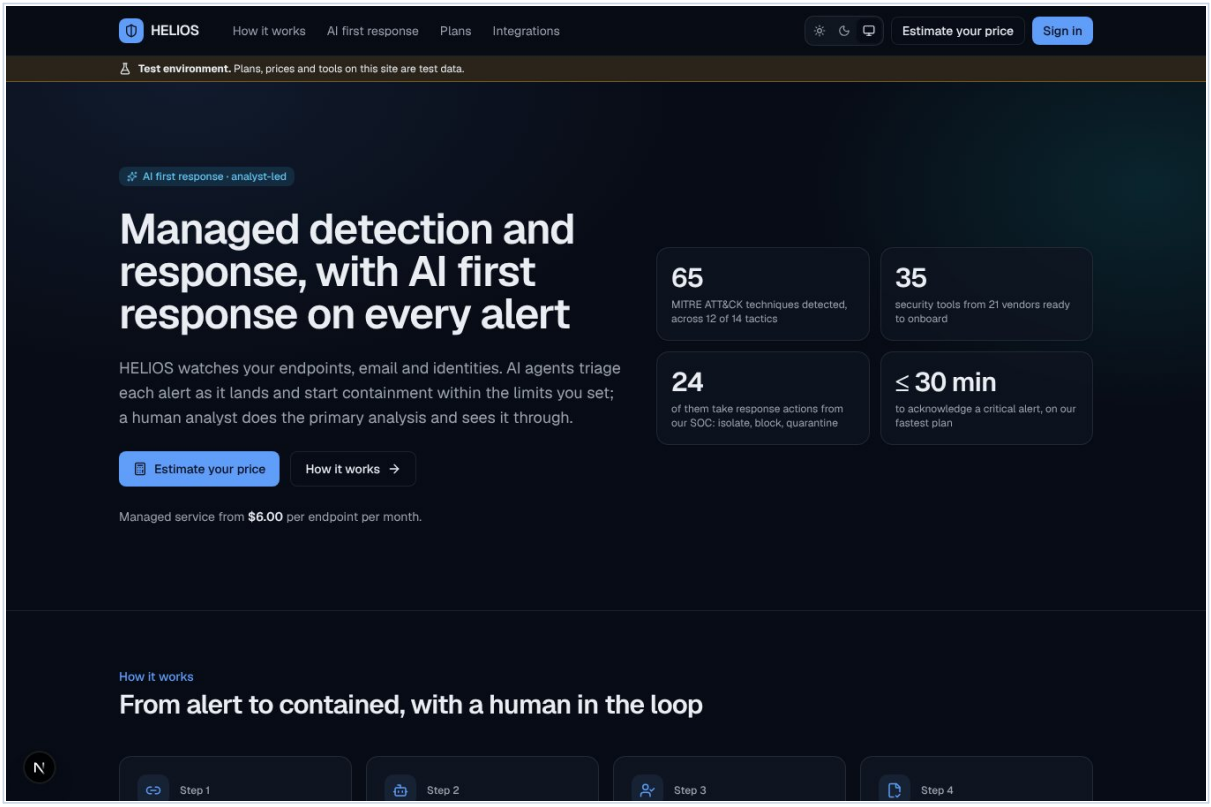
The Design tab in the console: priorities, coverage now vs with the suggested stack.

7.6 Tool catalog

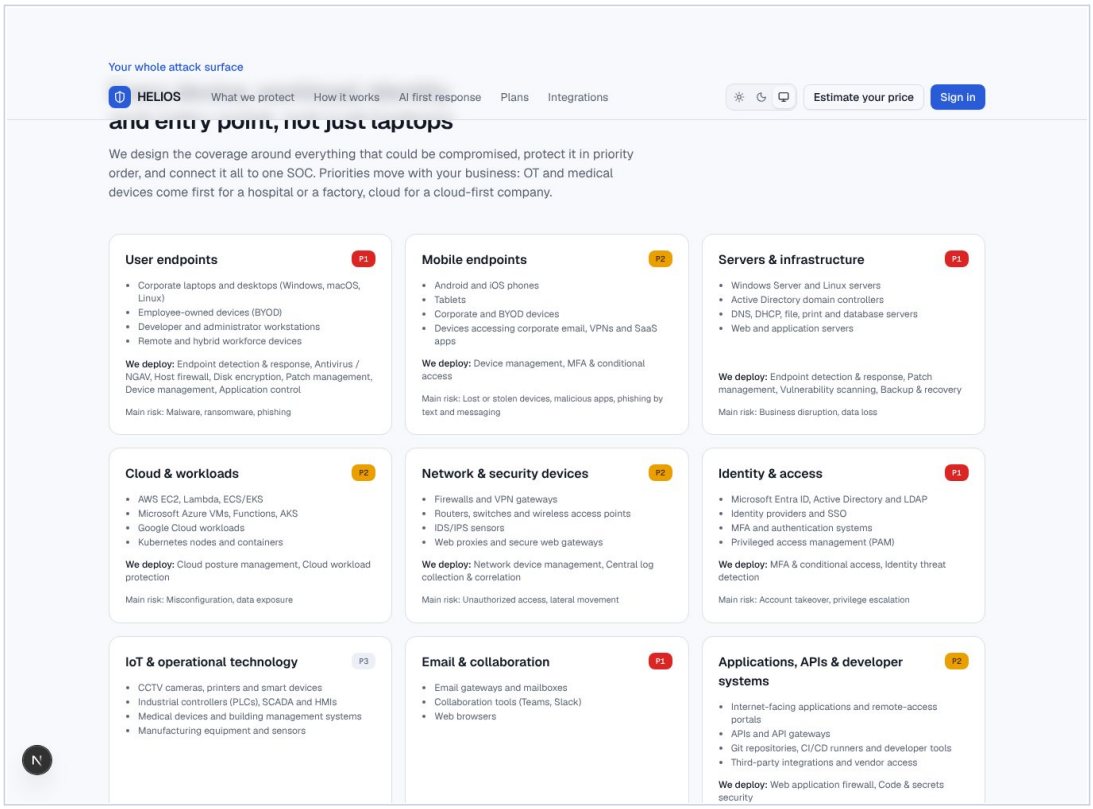
74 tools across 22 categories: EDR/XDR, antivirus, MDM/UEM, patch and vulnerability management, firewall and web filtering, DLP, email security, identity/SSO/MFA, SIEM, backup, security awareness, mobile threat defense, cloud security, NDR, PAM, OT/IoT, network device management, web app and API protection, code security, SIEM, ticketing, chat and automation (SOAR). Where a vendor publishes a list price, it is seeded with its source; otherwise the tool is marked "by quote" or usage-based. Prices were checked against vendor pages. Examples: GitHub Secret Protection at $19 and Code Security at $30 per committer, Cloudflare Pro at $20 and Business at $200 a month on annual billing, and Snyk Team at $25. Prices that couldn't be verified (some Microsoft Defender SKUs) are left by quote rather than guessed.

8. Public website and estimator

Visitors who aren't signed in are redirected from / to /home; /home and /estimate are public. The pages are built from the company's real catalog, plans and detection coverage, not marketing copy that can drift from the product. Every part can be switched off under Settings → Public website.



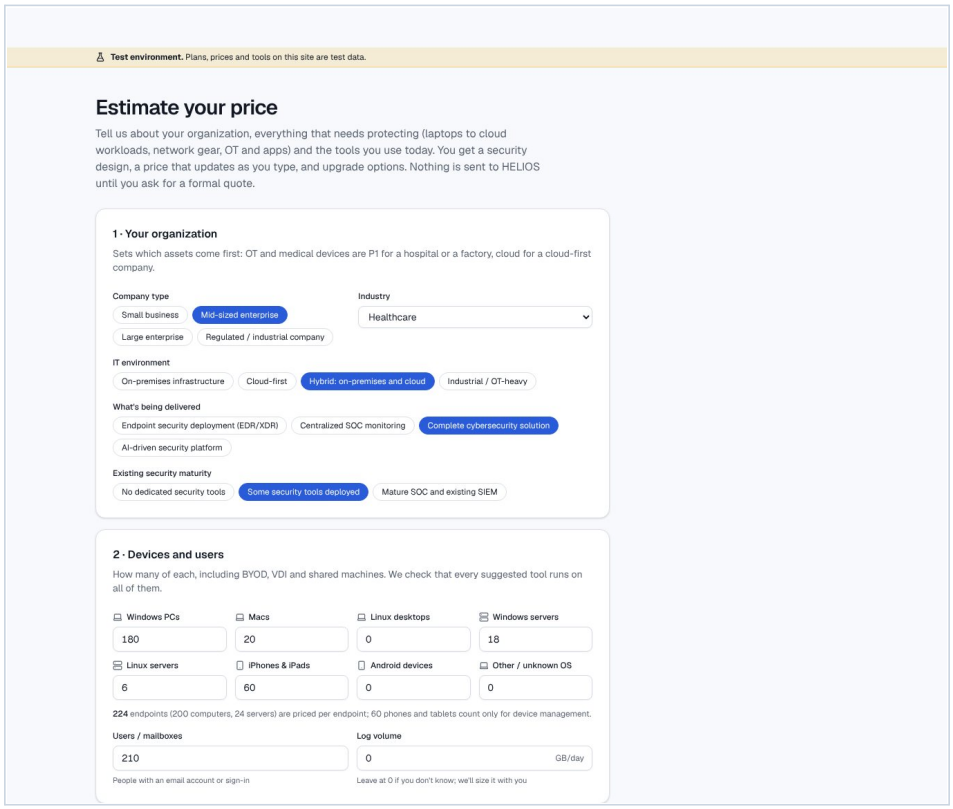
Home page: the service, live figures from the platform, and a link to the estimator.



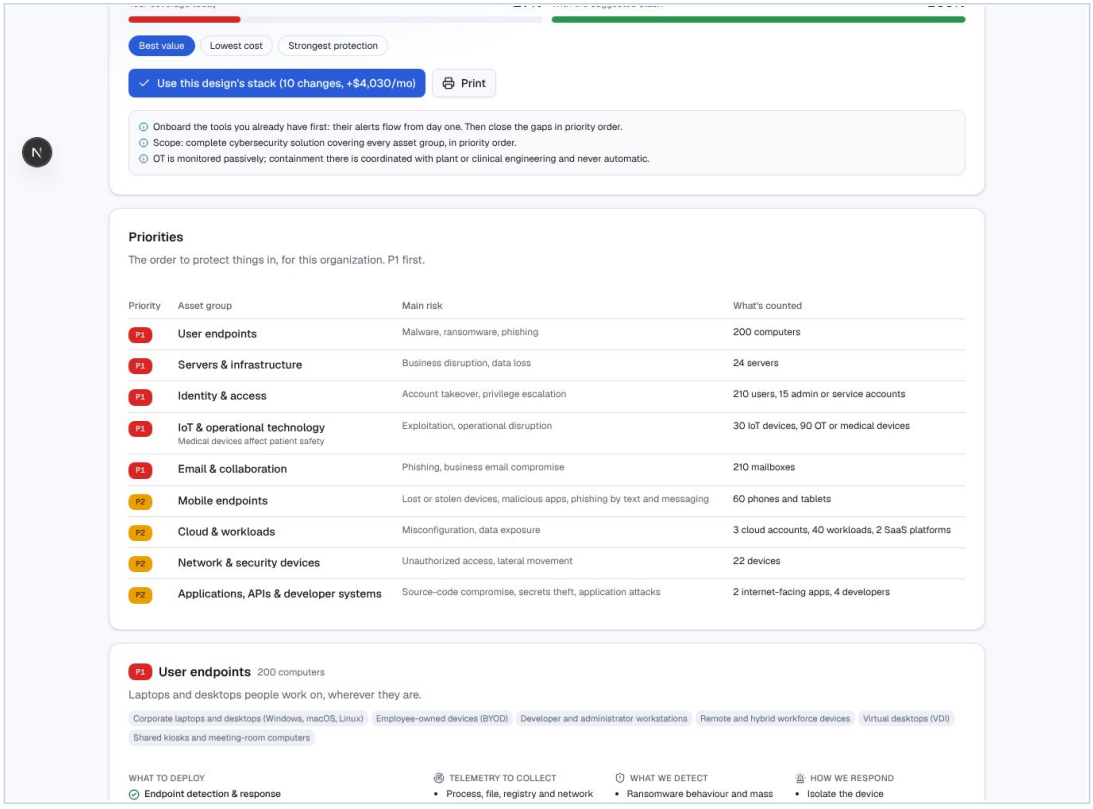
Home page: the whole attack surface, nine groups with what's deployed and the main risk.

8.1 The estimator

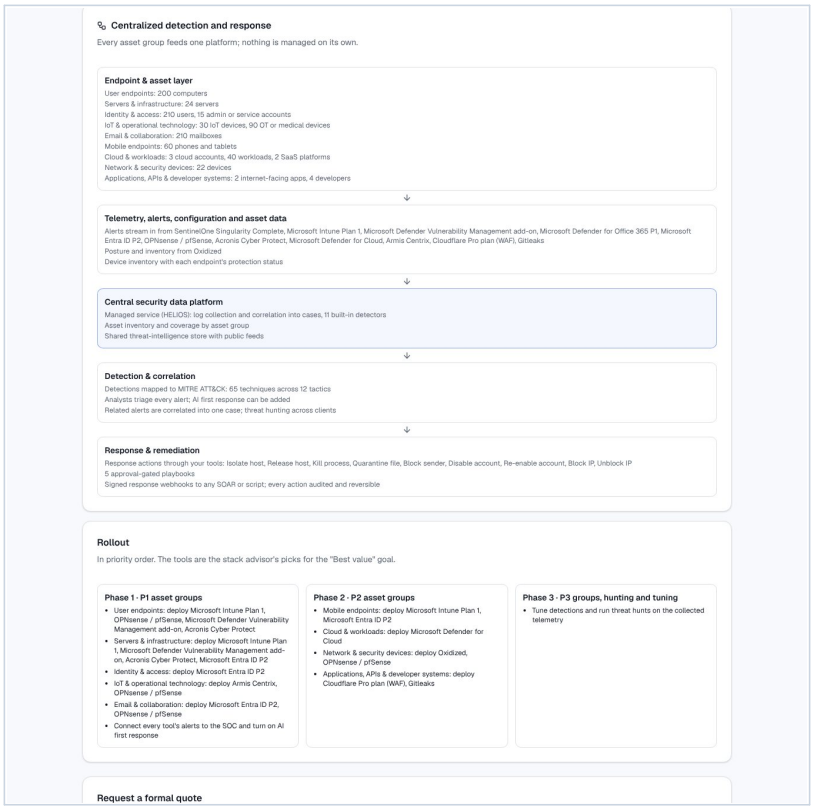
1. **Your organisation:** company type, industry, IT environment, what's delivered and maturity. These set the priorities.
2. **Devices and users:** computers, servers and phones by OS, users and mailboxes, log volume.
3. **The rest of the attack surface:** cloud, network, identities, IoT/OT and applications.
4. **Tools you use today:** recorded as theirs, so the upgrade review compares against them.
5. **Results, live as they type:** price, security design (priorities, architecture, rollout), upgrade options and the advisor.



Estimator: organisation, devices by OS, and the rest of the attack surface.



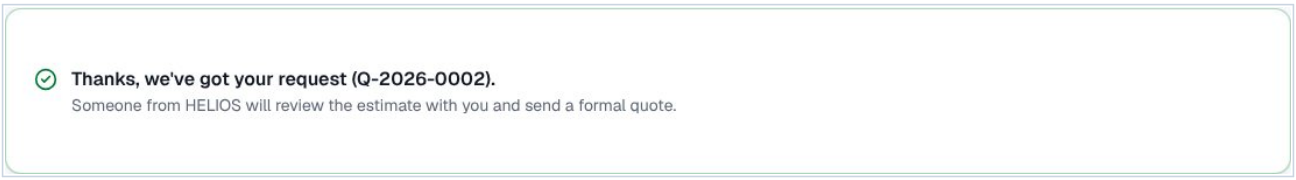
Estimator: the security design, with priorities for this organisation.



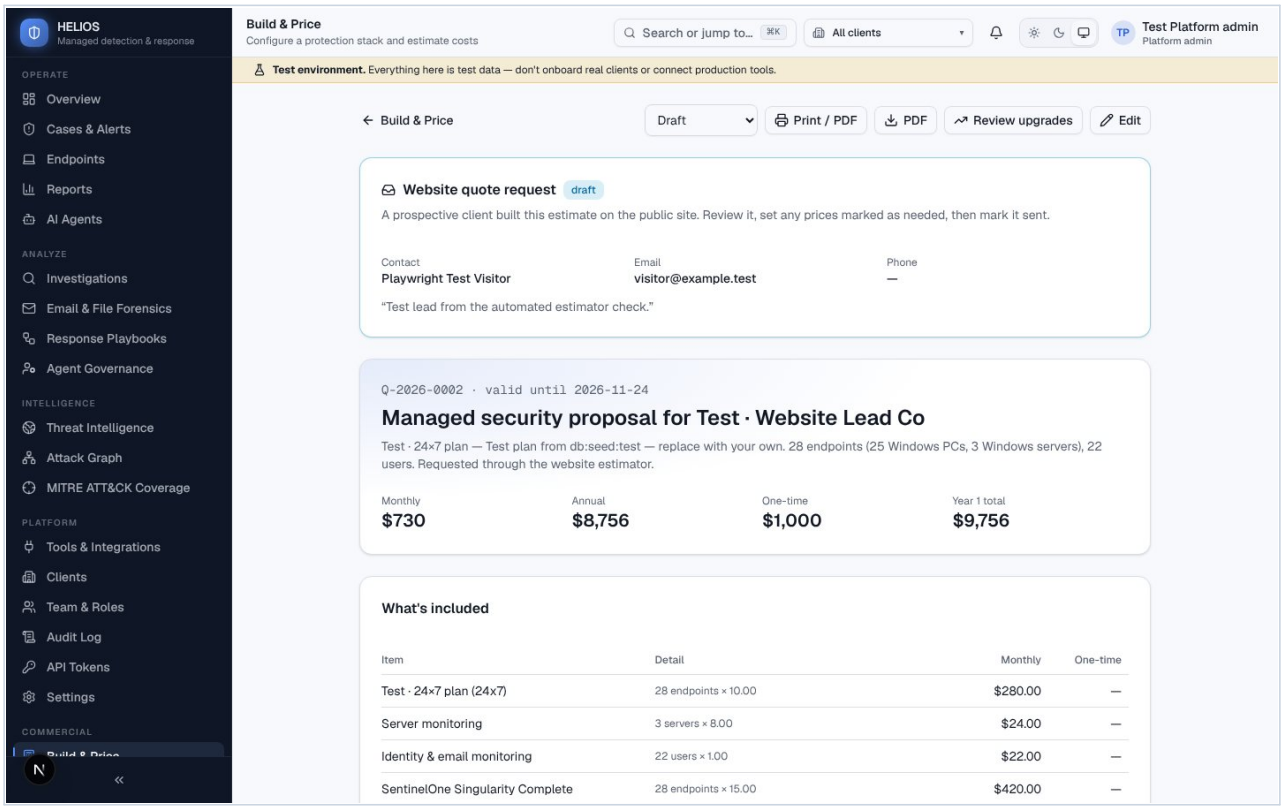
Estimator: centralised detection and response architecture and phased rollout.

8.2 Safety of a public price tool

- The pricing context sent to the browser is sanitised: no costs, no resale ratio, no client counts.
- Anything a visitor submits has its commercial terms reset on the server (discount, exchange rate, usage overrides, tax), so a crafted request can't award itself a discount.
- Quote requests have a honeypot field, a consent check and per-address rate limits; the AI advisor has a daily budget, after which the rules answer.
- A request becomes a draft quote (source = website) with the contact details, notifies every staff role that can view pricing, and is audited.



Confirmation after a visitor requests a formal quote.



The same request in the console, as a draft quote ready for review.

9. Security and trust

Concern	How it is handled
Authentication	Auth.js credentials with lockout after repeated failures; users re-read on every request.
Authorisation	11 roles, domain queues and client scope enforced in every page, server action and API call.
Secrets	Ingest, agent and API tokens shown once and stored as hashes; provider keys sealed with AES-256-GCM, only the last four characters kept in clear.
Audit	Hash-chained, advisory-locked, RESTRICT foreign keys, verifiable, exportable.
Response	Signed webhooks to the client's connector; nothing claimed without confirmation; rollbacks.
AI	Evidence grounding, a deterministic policy, client consent, kill switch, per-agent autonomy and rate limits.
Detonation	SSRF guard, every hop vetted, egress proxy support; internal-looking names refused.
Public site	Sanitised context, server-side reset of terms, honeypot, consent, rate limits, AI budget.
Dependencies	Next.js kept on a patched release; hardcoded API keys removed from the legacy sources.
Client data	Client copies of reports leave out AI working notes; quotes never carry cost or margin.

10. Test environment and test data

Test data never mixes with production. A platform setting marks the whole database as a test environment, and every page shows a banner. Test clients are badged wherever they're listed and left out of commercial figures in production. npm run db:test-env converts a database into a test environment: records that belong to no client move to a labelled test client, a test admin is added, and so is the test data.

- Labelled test clients (Test · Clinic, Test · Retail…) with plans, tools, assets across every group, and cases.
- The 48 ATT&CK attack scenarios and the AEGIS governance scenarios are test fixtures, never in-app generators.
- Test prices for every price-book item, so quotes can be exercised end to end.
- A separate integration database (helios_test) for the Postgres-backed test suite.

11. Quality and verification

Check	Result
TypeScript type check	0 errors
ESLint	Clean
Unit tests (Vitest)	193 passing: detectors, scoring, forensics parsers, archives, evtx, VBA, policy, pricing, upgrades, advisor, AI advisor guardrails, attack surface, designer and more
Integration tests (Postgres)	18 passing: case writer, correlation, audit chain, API tokens, inventory, client stack, quotes
Production build	next build succeeds; production smoke test (/ redirects to /home for visitors)

Check	Result
Browser checks (Playwright)	Home page, estimator design, lead submission, inventory import, client design and upgrade review, quote view, settings
CI	GitHub Actions runs lint, type check, unit tests, migrations, the integration suite and a production build

Bugs found while porting and testing were fixed at the root rather than worked around. Examples:

- the legacy SIEM re-filed every finding on every ingest, which de-duplication now prevents;
- network IPs were dropped because of a field-name mismatch;
- a persistence rule matched "cat" and "format";
- the threat-intel detector ignored destination addresses;
- the advisor once suggested switching a client to the tool they already owned;
- a SaaS backup was counted as protecting servers;
- a crafted public submission could set its own discount.

12. Limits and next steps

12.1 Known limits

- Response actions on client systems need a response connector (a SOAR, an automation script or a vendor API) behind the signed webhook. Without one they're done by hand, by design.
- Link detonation is HTTP-level analysis of the landing page. It is not a full browser sandbox with JavaScript execution.
- Some vendor prices aren't published and stay "by quote" until the company enters its own.
- The AI advisor and first responder need a configured model; without one, the deterministic engines answer.
- Plans, rates and SLAs must be entered by the admin before real quotes can be saved.

12.2 Suggested next steps

1. **Go-live setup:** enter the plans, price book and exchange rates, configure an AI provider, enable the threat feeds, and switch the environment to production.
2. **Connectors:** build response connectors for the most common client tools (Defender, CrowdStrike, SentinelOne, Entra ID, firewalls), so containment runs end to end.
3. **Native integrations** for cloud posture (AWS, Azure, GCP) and OT monitoring, feeding the new asset groups with live telemetry.
4. **Client portal growth:** scheduled report emails, compliance evidence packs, and approvals by mobile push.
5. **Local AI:** validate an on-premises model (vLLM or Ollama) for clients that need data residency.
6. **Hardening:** an external penetration test, SSO for staff, and backup and restore drills for the database.

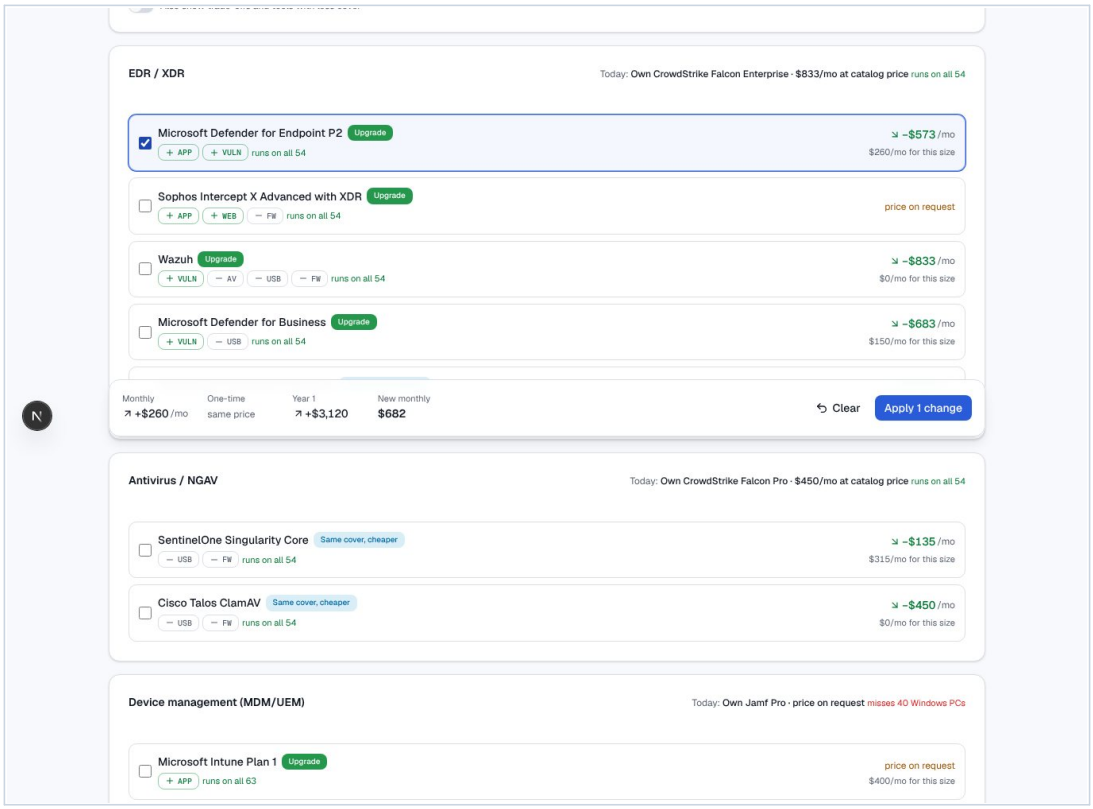
Appendix A. Routes

Area	Routes
Public	/home, /estimate, /login
Operate	/ (overview), /cases, /cases/[id], /endpoints, /reports, /ai
Analyze	/investigations, /forensics, /playbooks, /governance
Intelligence	/threat-intel, /attack-graph, /mitre
Platform	/integrations, /tenants, /tenants/[id], /team, /audit, /api-tokens, /settings
Commercial	/pricing (Build, Design, Upgrades, Advisor, Compare, Line items), /pricing/quotes/[id]
Machine APIs	POST /api/ingest/[id] (vendor alerts, telemetry, inventory), POST /api/governance/evaluate, GET /api/threat-intel/blocklist, GET /api/health
REST API v1	/api/v1/me, /api/v1/cases, /api/v1/cases/[id], /api/v1/cases/[id]/comments, /api/v1/indicators, /api/v1/metrics

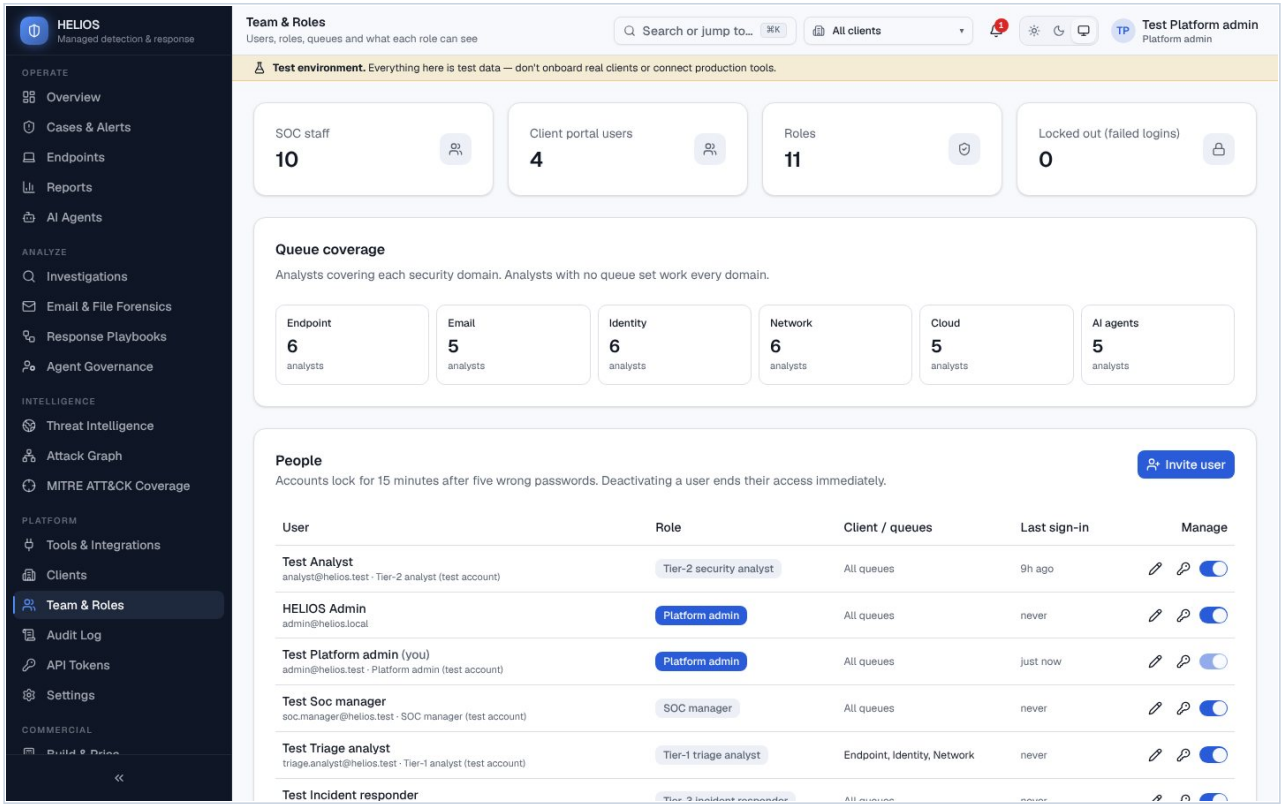
Appendix B. Source layout

Path	Contents
src/app/(app)	The console: every module page and its server actions
src/app/(site)	The public website: home and estimator
src/app/api	Ingest, governance, threat-intel, health, auth and REST API v1
src/lib/cases, siem, investigations, forensics, governance	The security modules and the shared case writer
src/lib/ai, response, playbooks	AI first response, the response policy and executor, playbooks
src/lib/threat-intel, mitre, audit.ts	Indicator store and feeds, ATT&CK catalog and coverage, audit chain
src/lib/assets	Attack-surface model: capabilities, estate, surface, coverage, designer, inventory
src/lib/pricing	Calculator, endpoint mix, upgrades, advisor (rules and AI), client stack, public sanitising
src/lib/pdf, reports.ts	PDF documents and report metrics
prisma/	Schema, 11 migrations, the facts seed and the labelled test seed
docs/	architecture.md, porting-notes.md and this document
legacy/	The four original projects, kept for reference

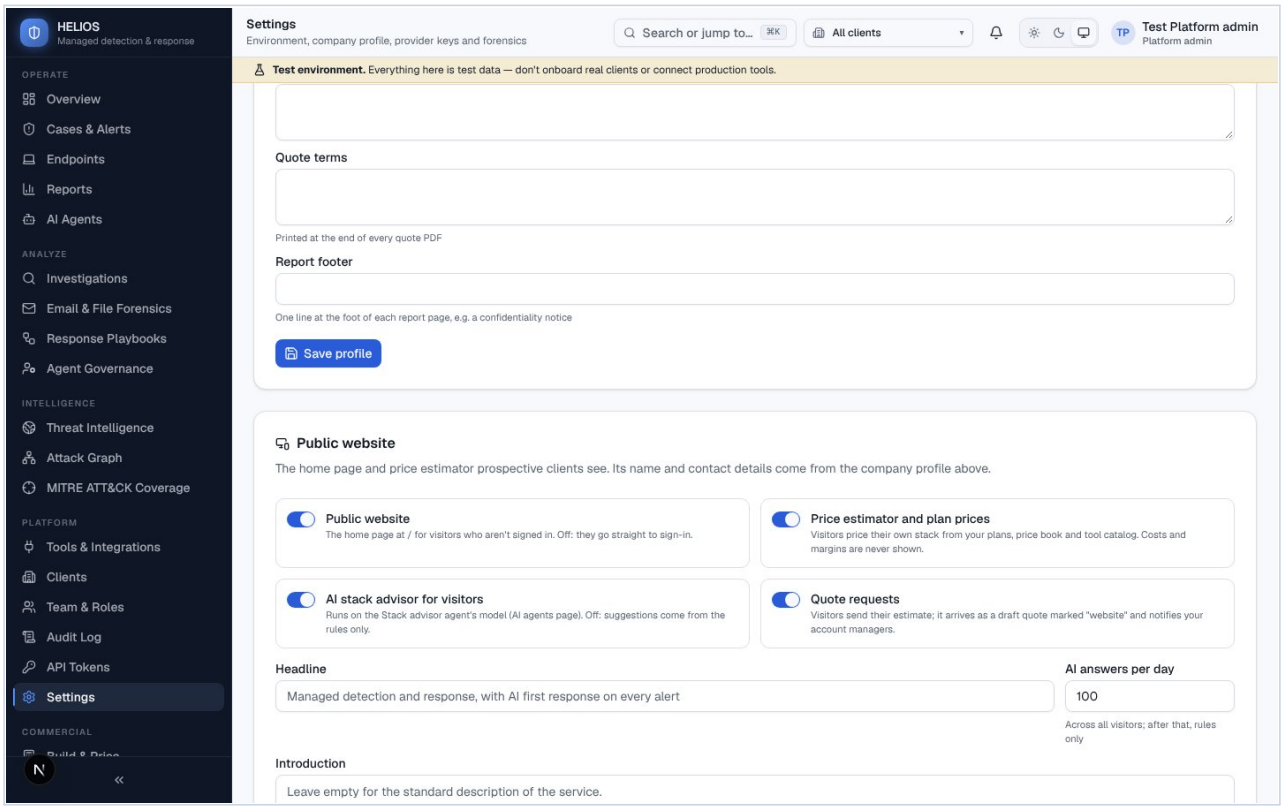
Appendix C. More screens



Estimator: upgrade options per layer, against the tools the visitor already has.



Team & Roles: queue coverage by domain and user management.



Settings: the public website switches and the AI answer budget.